# Preprint: Investigating Deceptive Design in GDPR's Legitimate Interest

Lin Kyi
Max Planck Institute for Security and Privacy
Bochum, Germany
lin.kyi@mpi-sp.org

Sushil Ammanaghatta Shivakumar
Max Planck Institute for Security and Privacy
Bochum, Germany
sushil.shivakumar@mpi-sp.org

Franziska Roesner
University of Washington
Seattle, United States
franzi@cs.washington.edu

Cristiana Santos
Utrecht University
Utrecht, The Netherlands
c.teixeirasantos@uu.nl

Frederike Zufall
Max Planck Institute for Research on Collective Goods
Bonn, Germany
zufall@coll.mpg.de

Asia J. Biega
Max Planck Institute for Security and Privacy
Bochum, Germany
asia.biega@mpi-sp.org

## ABSTRACT

Legitimate interest is one of the six grounds for processing data under the European Union's General Data Protection Regulation (GDPR). The flexibility and ambiguity of the term "legitimate interests" can be problematic; coupled with the lack of enforcement from legal authorities and different interpretations from the various data protection authorities, legitimate interests can be taken advantage of as a loophole to collect more user data.

Drawing insights from multiple disciplines, we ran two studies to empirically investigate the deceptive designs used when legitimate interests are applied in privacy notices, and how user perceptions line up with practice. We identified six deceptive designs, and found that the ways legitimate interest is applied in practice does not line up with user expectations.

## CCS CONCEPTS

• **Security and privacy** → **Human and societal aspects of security and privacy**; • **Human-centered computing** → **User studies**; • **Applied computing** → *Law*;

## KEYWORDS

Deceptive Design, Dark Patterns, GDPR, Consent, Privacy Notice, Legitimate Interest, Human-Computer Interaction

**ACM Reference Format:**
Lin Kyi, Sushil Ammanaghatta Shivakumar, Franziska Roesner, Cristiana Santos, Frederike Zufall, and Asia J. Biega. 2023. Preprint: Investigating Deceptive Design in GDPR's Legitimate Interest. In *Proceedings of ACM CHI Conference on Human Factors in Computing Systems (CHI '23).* ACM, New York, NY, USA, 34 pages. https://doi.org/XXXXXXX.XXXXXXX

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
*CHI '23, April 23 - 28, 2023, Hamburg, Germany*
© 2023 Association for Computing Machinery.
ACM ISBN 978-1-4503-XXXX-X/18/06…$15.00
https://doi.org/XXXXXXX.XXXXXXX

## 1 INTRODUCTION

The European Union's General Data Protection Regulation (GDPR) outlines legal grounds for the processing of personal data to be lawful (Article 6), including the legal basis of consent and legitimate interest, amongst other grounds [14]. *Legitimate interest* is defined in Article 6(1)(f) of the GDPR as the processing that is *"necessary for the purposes of the legitimate interests pursued by the controller or by a third party* [14, 19]. Pursuant to this paper, *data controller* refers to a website or company that is processing personal data, such as service providers, advertisers, and consent management platforms (CMPs) [69].

While the practical implementations of the legal basis of consent have already been studied in a variety of contexts [40, 51, 60, 69], the usage of legitimate interests as a legal basis for data processing by websites remains relatively unexplored. Yet, as highlighted by legal scholars, out of all legal grounds under the GDPR, legitimate interest is the most ambiguous one because it allows for broad interpretations of different processing purposes [28, 44]. In fact, the legal uncertainty of which data processing purposes should fall under the legal basis of legitimate interest is currently the subject of great attention at the EU level by the European Commission [25], Data Protection Authorities (DPAs) [18, 19], the EU Court of Justice (ECJ) [17], as well as other national courts. Moreover, the lack of legal enforcement from regulators and courts may allow for this legal basis to be exploited by data controllers as a loophole for dubious data practices [28, 44]. Hence, there is a need for further investigation into the use and applicability of legitimate interests in practice.

Even though legitimate interests allow data controllers to process data without explicit permission from the user, they have the right to *object* to legitimate interests (Art. 21(1) GDPR). As a result, legitimate interests appear in website privacy notices[1] more and more commonly (see Figure 1 for an example notice design). The potential for legitimate interest to be exploited to collect more user data raises the question of whether its practical implementations use

[1]The notices we focus on this paper are also often called "consent notices", "cookie banners", or "cookie pop-ups". We use the term "privacy notices" (not to be confused with "privacy policies") here, since we refer to notices that do not just ask for consent but also inform users of data processing based on legitimate interests.

any deceptive designs. In the context of consent, it has been shown that data controllers—including advertisers, service providers, websites, and consent management platforms (CMPs)—use deceptive design in their privacy notices [40, 51, 60, 70].

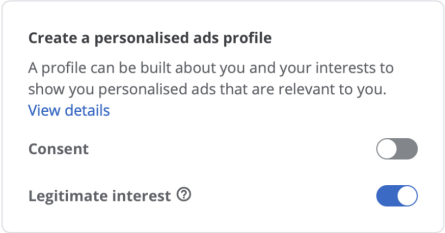



**Figure 1: An example of a consent-legitimate interest toggle. This is a legally dubious design element because data collection purposes can only rely on either consent or legitimate interest, not both [63]. Additionally, it may be unclear if data is being collected even if "Consent" is switched off.**

Deceptive designs, or dark patterns, are defined as user interfaces which lead users into making decisions that benefit the online service [12, 52, 59].[2] In the context of privacy and data protection, we are interested in deceptive designs that deceive users into making *poor privacy decisions*, such as making it difficult to object to data collection or using obscure or technical language [10, 40, 60]. Exactly how often legitimate interests appear in privacy notices, what deceptive designs arise in this context, and whether the amalgamation of consent and legitimate interests settings into one notice makes decision making harder for users, remain open questions, which we investigate in this paper.

Beyond implementation practices and deceptive designs, it is also important to understand user perceptions of legitimate interests since they, as data subjects, are directly affected by an interference with their right to the protection of personal data from Art. 8 of the EU Charter of Fundamental Rights of the European Union [62].

Despite the many issues that legal scholars have noticed regarding the use of legitimate interests [28, 44], there is a lack of research investigating how this legal basis is applied in practice by data controllers and perceived by users. To the best of our knowledge, this paper is one of the first to provide the relevant empirical evidence. Drawing insights from multiple disciplines (the authors of this paper consist of legal scholars specialized in EU data protection law, those with a computer science background, and also researchers with a psychology and HCI background), we conduct a two-part investigation of legitimate interests. First, we examine the practices and deceptive designs in the usage of legitimate interests by data controllers, as evidenced in website privacy notices. Second, we study user understanding and perceptions of legitimate interests as well as of the purposes for which data is being collected on this basis.

The contributions of this paper are:

(1) We examined how the legal basis of "legitimate interests" is being used in practice by data controllers (publishers and CMPs) in privacy notices on their websites;
(2) We identified deceptive design patterns used by data controllers when it comes to implementing the legal basis of legitimate interests for processing (Art. 6(1)(f) GDPR); and
(3) Building on our findings from the first study, we investigated what end-users perceive about data collection purposes to provide a user context to legitimate interests practices.

*Study one* identified deceptive designs used for the legal ground of legitimate interest. Out of the 10,000 sites we crawled, 474 (4.74%) included "legitimate interest(s)" in their privacy notices, and we found that various UI and linguistic deceptive designs were present in most of these notices. Legitimate interests, when disclosed, are often difficult to object to, are designed in ways that might confuse users and lead to lower user engagement rates. Moreover, our results demonstrate that IAB Europe's Transparency and Consent Framework (TCF) [24] has a major role in how legitimate interest is applied in practice.

Based on the practices identified in the first study, *study two* surveyed 400 users to understand how users perceived these practices. We found that users were wary of the data collection practices that are commonly used in practice, and that a data collection purpose's *user acceptance*, meaning whether users find a purpose essential or are comfortable with it, is most impacted by who it is believed to benefit: users are less likely to feel comfortable sharing their data if they believe a purpose benefits data controllers more than other stakeholders. Overall, we found that the ways legitimate interests are used in practice are not in line with user beliefs about how their data should be used, indicating that user preferences should be taken into account when creating and revising data protection laws and defining industry standards.

## 2 BACKGROUND

### 2.1 Legal Background

**Legal requirements for processing personal data.**

*Legal basis.* As the processing of personal data constitutes an interference with the right to protection of personal data in Art. 8 EU Charter [62], it requires a justification based on Art. 8(2) of the EU Charter. This justification may be provided by the consent of the person concerned, or through "some other legitimate basis laid down by law". This requirement is substantiated by Art. 6(1) (a-f) of the GDPR that lists potential legal grounds for the processing of personal data to be legitimate. Personal data shall only be processed if at least one of six legal grounds listed in that Article apply: (a) consent the data subject, (b) performance of a contract with the data subject, (c) compliance with a legal obligation imposed on the controller, (d) protection of the vital interests of the data subject, (e) performance of a task carried out in the public interest, or (f) legitimate interests pursued by the controller, subject to an additional balancing test against the data subject's rights and interests.

*Applicability of the GDPR and ePrivacy Directive.* While the GDPR applies to the processing of personal data, the ePrivacy Directive provides rules on the confidentiality of data on the user's device. Whenever cookies and other tracking technologies are stored and

[2]We generally use the term "deceptive design" to refer to this kind of design pattern in this paper, but acknowledge that other terms, such as "misleading" or "manipulative", may be more precise in certain cases. The term "dark pattern" has been criticized [72].

read from the user's device, the ePrivacy Directive [22] requires controllers to request consent for the storage of such cookies in Art. 5(3) for certain purposes for processing data (such as advertising). Based on a recent ruling by the European Court of Justice (ECJ) [2], the GDPR and the ePrivacy Directive thus apply in parallel. A follow-up question is then whether in case of cookies, where Art. 5(3) ePrivacy Directive requires consent for the processing of personal data, a justification based on legitimate interests (Art. 6(1)(f) GDPR) may still apply.

**Legal requirements for the application of the legal basis of legitimate interest.**

*Definition of the legitimate interest legal basis.* This legal basis (Art. 6(1)(f)) is elaborated by Article 29 Working Party (29WP) in its Opinion 217 on the notion of legitimate interests of the data controller [19]. [3] Accordingly, processing personal data will be lawful when it is necessary for the purposes of the legitimate interests of a controller or by a third party to whom data was disclosed to. The general provision on legitimate interest is open-ended, with a broad and unspecific scope [19], meaning that it can be relied upon a wide range of purposes and it is not purpose-specific, as long as its requirements are satisfied. This flexible definition also carries heightened obligations on controllers to balance its own interests with the rights and interests of users.

*Role of legitimate interest.* The 29WP recognises the role and usefulness of this legal basis provided that its requirements are fulfilled [19]. Legitimate interest gives data controllers the ability to innovate and provide better services, while ideally keeping them accountable for their actions [31]. It aims at a balanced approach, which ensures the necessary flexibility for data controllers for situations where there is no undue impact on data subjects, while at the same time providing sufficient legal certainty and guarantees to data subjects that this open-ended provision will not be misused [19].

*Requirements.* The open-ended nature of this provision raises important questions regarding its exact scope and application [19]. The mere existence of a legitimate interest of a website is not sufficient to legitimize data processing. It is mandatory that such processing is necessary for the purposes of a given interest. Given the required justification of an interference with the right to the protection of personal data by Art. 8 EU Charter [62], these legitimate interests may justify data collection if they override the data subject's interests and rights, such as the right to privacy [1, 16]. Accordingly, some obligations impend over controllers:

(1) they are required to perform a *balancing decision* in every single context as to whether this requirement is met;
(2) they are obliged to inform users about the specific legitimate interests pursued, and about the right to object to those (Arts. 13(1)(d), 14(1)(b), 21(1) GDPR);
(3) they must pursue legitimate interests that are "lawful", "sufficiently clearly articulated" (i.e., transparent) and "represent a real and present interest" [19, p. 25,52]; and
(4) they must use such interests under processing purposes that are specific (sufficiently detailed) and explicit (unambiguous, not hidden), and understood in the same way by everyone involved.

*Relationship between the legitimate interest legal basis and other legal bases.* Legitimate interest can be seen as a complementary to other legal bases. It may help to prevent consent fatigue [64] and over-reliance on other legal grounds (e.g., consent or contract) [19]. Legitimate interest should not be used as a "catch-all","open door" or "the weakest link" ground to fill in gaps for rare and unexpected situations where the other legal basis are not applicable [19]. Legitimate interest should neither be seen as a preferred legal basis, should not be automatically chosen, or its use unduly extended on the basis of a perception that it is less constraining than the other grounds legitimizing data processing [19].

**Design requirements.** Certain data protection rules apply to deceptive design. In particular, *default settings* must be designed with data protection in mind, and hence, data controllers must "implement appropriate technical and organisational measures which are designed to implement data protection principles" according to Art. 25 GDPR. They must ensure that, "by default, only personal data which are necessary for each specific purpose of the processing are processed". Promoting the idea of *"data protection by design"* through this provision, the GDPR does not get more specific in regulating deceptive designs.

**Consent Management Platforms.** Consent Management Platforms (CMPs) provide privacy notices that can be embedded in websites to enable streamlined compliance with the legal requirements for consent mandated by the ePrivacy Directive and the GDPR. Hils et al. found that several CMPs used legitimate interests as a way of collecting data [40]. Matte et al. found that 19% of advertisers collect data under legitimate interests grounds [53] where consent should be used instead. Santos et al. found that CMPs offer default consent banners featuring deceptive designs [69].

The GDPR and stakeholder guidelines provide a set of requirements for the formulation of legitimate interests. Due to the prevalence of legitimate interests being used to collect user data, it is important to identify the purposes that data controllers are using as legitimate interest purposes, and how users react to them.

## 2.2 Deceptive Design

**Why deceptive design is commonly used.** Deceptive design is ubiquitous in online privacy notices [60] because data controllers are incentivized to collect as much user data as possible for their own gains [32, 80]. As a result, users are faced with ambiguity about what is happening to their data [32, 48]. User data is a very valuable commodity in this current online economy [80]. Data can be used to benefit both the user and the data controllers by creating better personalized services, provide user and market insights, and gaining revenue from advertisers [13, 80].

**Deceptive design vs. poor design vs. nudging.** There is a fine line between poor design, nudging, and deceptive design [15, 59]. We cannot ascertain how intentional data controllers' deceptive design practices are, but research has shown that these design elements confuse and deceive users, as they can nudge most users

[3]The Article 29 Working Party (29WP) was the former European Data Protection Board, a European Union body whose purpose is to ensure consistent application of the GDPR and to promote cooperation among the EU's data protection authorities. While their opinions or guidelines are not formally binding, they hold much authority in member states and provide comprehensive guidelines for data controllers as to how they should apply the concept of personal data in practice.

into making poor decisions by taking advantage of user psychology [12, 34, 35, 43, 52, 59, 78].

Paternalism is the idea that UI designs should nudge, or influence, users into making decisions that are better for them [8, 73]. With deceptive design, we see the opposite; users are nudged into making decisions that are not in their best interests [32]. Regardless of the data controller's intentions, whether accidental or intentional, deceptive design is very effective because it can nudge most users into making poor decisions [12, 34, 35, 43, 52, 59, 78].

**Deceptive design in privacy notice consent settings.** Only 11.8% of privacy notices fit legal standards [60, 70] since most are riddled with deceptive designs [36, 60]. It is common to see default selections that highlight the "Select all cookies" option, and making it harder to reject them, hiding privacy-preserving choices, and overloading users with too many options and layers in a privacy notice [10, 32, 37]. In mobile applications, the situation with deceptive designs is even more severe due to the lack of GDPR enforcement in this space [45]; only 9.9% of apps included some form of privacy notice [46].

Previous work demonstrated the impact of deceptive designs in privacy notices: users are more likely to make consent decisions that benefit the service more than themselves [40, 60, 76]. Santos et al. stated that most of the research on the legality of privacy notices tends to focus on the user interface level, and less on the text within privacy notices [70]. They found that 89% of privacy notices violated the law with just their wording and framing of purposes; 50% were too vague, 30% used positive framing (i.e., making it sound like data collection only benefits the user), and 42.41% misled users by using false statements, which violates GDPR standards [70].

The majority of research has focused on the informed consent aspects of privacy notices, but not the legitimate interest aspects of privacy notices. Legitimate interest does not require user consent to collect data, but is still included in many privacy notices. Therefore, we are interested in investigating how legitimate interest is being used in privacy notices to expand on this research.

**Deceptive design regulation and enforcement.** Mostly recently, several data protection authorities (DPAs) and court decisions were issued and forbade certain deceptive design practices: preselection of choices [2]; difficulty to refuse consent as easily as to accept (e.g., several clicks are necessary to refuse data collection consent purposes) [3, 4]; misinforming users on the purposes of processing data and how to reject them [4, 50]. The future Digital Single Act (DSA) [61] will finally ban deceptive designs explicitly. It prohibits "online platforms to design, organise or operate their interfaces in a way that deceives, manipulates or otherwise materially distorts or impairs users' free and informed decisions" (Article 23a(1)).

Policy-making efforts attempt to address deceptive practices [9], but regulation within EU data protection law lacks operational guidelines for implementation by practitioners. As a result, there is a lot of freedom for interpretation when it comes to deceptive design within privacy notices. This is especially problematic because enforcement is still too slow compared to the speed and ubiquity of deceptive practices.

## 2.3 User Perceptions of Personal Data Collection

The majority of research on user perceptions of data collection practices have been related to personalization of services and advertisements. We expand on this literature by investigating user perceptions of legitimate interest practices. Previous work has shown that users are generally aware that AI and personalization services are reliant on user data to function [47], and have a general understanding of online tracking [13]. As a result, many users have concerns about their online privacy, and feel they have little control over their data [7].

Kozyreva et al. found in their survey of users that there is an *acceptability gap* in the use of personal data for personalization, where users are more likely to accept these personalized services and use them, but are less accepting of giving up the personal data needed for these services [47], which highlights the tradeoffs users need to consider in exchange for convenience online. Chanchary and Chiasson's study showed that users generally were accepting of online behavioral advertising (OBA), but had preferences for the kind of information they were willing to share online [13]. Overall, users were more concerned about third-party tracking on online banking sites compared to other websites (e-commerce, search engine, and social networking sites). When it came to sharing personal information, users were more willing to share location information, and demographic and computer information compared to personal identification and financial information [13].

# 3 STUDY 1: PRIVACY NOTICE WEB CRAWL

The purpose of our first study was to understand how legitimate interest is being (mis)used in practice, and identify deceptive designs that are prevalent when applying the legal basis of legitimate interest. As explained in Section 1 and 2.1, users have the right to object to data processing based on legitimate interests. Hence, our focus in this study was on privacy notices because they appear to more frequently allow users to express their legitimate interest preferences. Research questions we investigated in this study were:

(1) What are the data collection purposes used under legitimate interest grounds?
(2) What kind of deceptive designs are used when it comes to legitimate interest in privacy notices?
(3) Are the practices surrounding legitimate interest used in privacy notices legal?

## 3.1 Web Crawl Methodology

We created a web crawler to analyze 10,000 websites' privacy notices from the Tranco top sites list[4] which provides rankings that are oriented for research, and aims to be reproducible [68]. We created a script using Selenium for Python[5] which went through the top websites from March 12, 2022. We ran the script in May 2022 from a French IP address. Due to the GDPR's requirement that websites need to inform their users when their data is being collected [14], we expected every website to contain a privacy notice for us to analyze. However, we knew from our own observations

[4]https://tranco-list.eu/
[5]https://selenium-python.readthedocs.io/

that not every website mentioned their legitimate interests in their privacy notices, therefore we used a web crawler to investigate the prevalence and uses of legitimate interests from a larger dataset.

The Selenium library uses a driver which initiates an automated test software that opens up Google Chrome in another tab (using Chrome driver). The driver then opened websites individually from Tranco's top websites list, collected that webpage's data source, and checked if "legitimate interest" or "legitimate interests" appeared. If "legitimate interest(s)" was not found in the first page of the privacy notice, our crawler went to the next layer of the privacy notice, and searched for it there.

As CMPs use different wording in their privacy notices, such as "Show purposes" or "Select choices", for buttons that users can click on to modify their preferences, we created an additional script that identified these phrases used in our list of 10,000 websites. Overall, we found 63 such terms used on English websites, including "More options," "Customize", and "Learn more." Using this list of phrases, our crawler clicked the buttons containing these phrases if "legitimate interest(s)" was not found in the first layer.

In the second layer of the privacy notice, the crawler repeated the same steps; it looked at the page source, and searched for "legitimate interest(s)". If these words were not found, the crawler would mark it as not being present in the privacy notice. If the words were present, the crawler made note of which page(s) of the privacy notice it was in, and the number of clicks needed to access legitimate interest(s) in the privacy notice.

The crawler flagged websites that contained the phrase "legitimate interest" or "legitimate interests" in the HTML of the web page (which is almost always in the privacy notice), and took screenshots of the privacy notices that mentioned these phrases for the qualitative stage of data analysis. We took screenshots of the whole privacy notice, including ones that were long and required scrolling relevant pages containing "legitimate interest(s)". Refer to Figures 4 and 5 in the Supplementary Materials for examples of the privacy notices the web crawler flagged and screenshots it took. Additionally, we captured the text relevant to legitimate interest(s) using the Beautiful Soup Python library to supplement the screenshots[6]. This library scraped the text data by parsing over the HTML of the webpages.

We only went up to the second layer because the most relevant information for users tends to be on the first two layers; investigating deeper than these two layers womuld require very complex actions from our web crawler, most likely customized for individual privacy notices. Additionally, most users only tend to look at the first layer of a privacy notice [40].

*Dataset.* Our web crawler analyzed the top 10,000 websites from the Tranco list, and flagged 643 websites as containing "legitimate interest(s)" in the consent banner. Out of these sites, 474 were valid for our study. We excluded cases where i) the privacy notice was in a language other than English, ii) the website was changed or removed when we conducted our analyses, and iii) the website only contained the phrase "legitimate interest" in the HTML but not the privacy notice.

[6]https://beautiful-soup-4.readthedocs.io/en/latest/

## 3.2 Data Analysis

*Quantitative analysis:* Using the data from the web crawl, we conducted statistical tests to understand the relationship between implementation practices around the use of legitimate interest in privacy notices.

*Qualitative analysis:* We conducted a content analysis of our privacy notice screenshots taken by the web crawler. We analyzed the page(s) of the privacy notice "legitimate interest(s)" was found in, and focused on details relevant to legitimate interest in the annotating process. The annotating was performed by two annotators, including the main author of this paper and a co-author. The annotators initially used an inductive coding approach, which turned into a deductive approach once they knew what to look for. The annotators first met and coded 15 randomly selected privacy notices together to determine what is important for the analysis. They decided that in addition to focusing on UI design and linguistic elements relevant to legitimate interest, it would be important to keep track of:

- Whether the privacy notice mentions that legitimate interest can be objected to;
- Whether users can object to legitimate interest in the privacy notice (either by interacting with the privacy notice buttons or being re-directed to another page/website to object);
- Whether the privacy notice listed the purposes for which the data controllers were using legitimate interest for; and
- Whether there are elements showing a data controller is relying on both consent and legitimate interest as legal grounds (such as toggles, see Figure 1),

After coding the initial 15 notices together, the annotators coded the same set of 40 randomly selected notices independently. They had a few more meetings and maintained online communications to adjust and calibrate their codes. For the 55 notices which they coded together, the agreement rate was 84.8%, with a Cohen's kappa of $\kappa = 0.70$, which meant there was substantial agreement [57]. Since the interrater reliability rate was high, and privacy notices are often very similar to each other due to the standardized use of CMPs [40], the annotators halved the remaining set of notices and coded them independently. According to McDonald et al., it is acceptable to divide the qualitative analysis if there is a large dataset [56], such as ours with over 400 privacy notices.

## 3.3 Results

In our qualitative analysis of the 474 privacy notices that contained "Legitimate Interest(s)", we identified 87 codes, and 8 themes. See Section 3 of the Supplementary Materials for our codebook. We will be using terminology from recent qualitative CHI papers to discuss frequencies for our qualitative data in this section (see Figure 2) [21, 38].

*3.3.1 Prevalence and Usage of Legitimate Interests.* We found that 474 websites (4.74%) of the 10,000 sites we crawled included their legitimate interests in their privacy notices. Out of these websites, 273 (57.59%) websites mentioned their legitimate interests on the first page of the privacy notice, and 201 (42.41%) mentioned it after the user performs one click (e.g., the "next" or "show purposes" button). Common descriptions of legitimate interest used by most

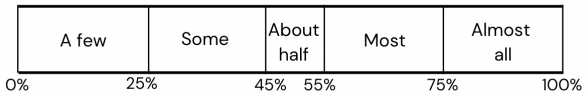



**Figure 2: The terminology used to represent the frequency of themes.**

websites were "legitimate business interest" and "processing without user consent"

In our analysis, every website that mentioned "legitimate interest" was using IAB Europe's TCF [24], and therefore reusing this framework's legitimate interest purposes in their privacy notices. This signifies the central role that the TCF has in the consent landscape [40]. These purposes are described in Section 2 of our Supplementary Materials.

When privacy notices described whose legitimate interests these purposes were meant for, almost all mentioned these purposes were for third party vendors, such as advertising partners, TCF and IAB vendors, social media partners, and analytics partners. Only a few mentioned that the service provider themselves were collecting data for their own legitimate interest purposes.

*3.3.2 Deceptive Design Elements.* Our analysis found several deceptive designs used when legitimate interest is included in privacy notices. We organized the legitimate interest-related deceptive design elements into three categories: i) general UI elements, ii) complex choice architectures, and iii) linguistic elements. Table 1 summarizes the UI, complex choice architecture, and linguistic deceptive elements we identified. We fully describe the deceptive designs we identified in Section 6.1.

**Table 1: The number of sites with different deceptive designs in the usage of Legitimate Interest (LI).**

| | Does the privacy notice mention that users can object to LI? | Can users object to LI in the privacy notice? | Complex choice architecture: Is there both a LI and consent toggle present? | Does the privacy notice list the LI purposes? |
|---|---|---|---|---|
| **Yes** | 473 (99.8%) | 464 (97.9%) | 147 (31%) | 409 (86.3%) |
| **No** | 1 (0.2%) | 10 (2.1%) | 327 (69%) | 65 (13.7%) |

*3.3.3 General UI deceptive design elements.* We noticed that i) privacy notices lacked an option to object to all legitimate interest-based purposes, and instead prompted users to individually de-select them (often at purpose and/or third party vendor level, see Figure 3 for an example); ii) accessing legitimate interest purposes require users to click through several pages, and iii) legitimate interest sections may not be available on the first page of privacy notices (seen in 42.41% of our privacy notices).

*3.3.4 Complex choice architectures.* Complex choice architectures refer to UI deceptive design elements that complicate the user's interactions with a website's UI in the context of decision making. Such elements were observed in our analysis (see Figure 1) and included: i) toggles that rely on both consent and legitimate interest as legal bases for collecting data for the same purposes, a practice which has been declared illegal [63]; ii) making it difficult to object to legitimate interest by directing users to the privacy policy or the third party vendor's website to object to processing; and iii) requiring users to expand each legitimate interest purpose in the privacy notice to manually opt out of each preselected purpose.

*3.3.5 Linguistic deceptive design.* Given that users may have varying commonsense interpretations of the term "legitimate interest", we considered a privacy notice to use linguistic deceptive design when it had poor, or missing explanations of what legitimate interest meant. Our analysis yielded several observations. Firstly, we found placebic explanations [20] of legitimate interest, with websites providing mostly tautological definitions of what the concept means, e.g., *"How does legitimate interest work? Some vendors are not asking for your consent, but are using your personal data on the basis of their legitimate interest"*. Secondly, some websites mentioned "legitimate interest" without providing any definitions. Thirdly, most privacy notices did not mention whose legitimate interests the data processing would benefit. Lastly, only 86.3% of privacy notices listed purposes for which data was collected on the basis of legitimate interest.

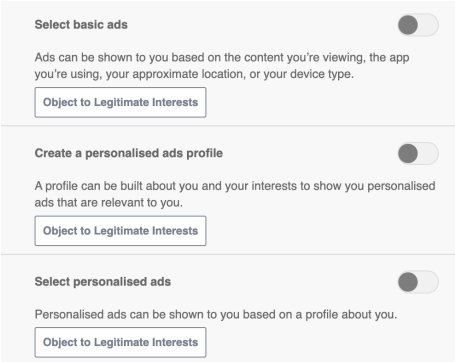



**Figure 3: Users are often required to individually object to legitimate interest at the purpose and/or vendor level.**

*3.3.6 Positive Framing.* Most privacy notices used positive framing when describing why users should accept a data collection purpose, such as mentioning that user data provides users with free services, that more data provides better results, and that accepting cookies ensures proper site functioning. This result aligns with prior findings on the framing of privacy notice purposes [70]. Highlighting the positive aspects of processing makes users pay less attention to other (negative) aspects (e.g., targeted advertising) [11] which are important for a meaningful and informed decision.

*3.3.7 Advertising.* Using legitimate interest for advertising purposes plausibly violates the lawful principle (Article 5(1)(a)GDPR), hence rendering the practice unlawful [6, 54, 63]. Yet, many websites disclosed that they were processing data for advertising purposes on the basis of their legitimate interests. We found that in those

cases the privacy notices implemented the TCF, which lists several advertising purposes under legitimate interest.

# 4 STUDY 2: USER REACTIONS TO LEGITIMATE INTEREST AND CONSENT PURPOSES

Based on the results of our web crawl study, we conducted a survey to better understand how users react to various data collection purposes. The full survey is available in Section 4 of our Supplementary Materials.

The research questions for this study were:

(1) Does the website category impact user opinions of which data collection purposes are acceptable to be used?
(2) What is people's understanding of the term "legitimate interest"?
(3) What do people expect or think is reasonable for companies to collect under legitimate interest?
(4) What do people think the harms associated with data collection under legitimate interest purposes are?

## 4.1 Methodology

*4.1.1 Survey design.* We implemented our survey using Qualtrics. The median time needed to complete the survey was around 10 minutes. After briefly explaining the purpose of our survey, we asked general background questions such as whether participants have ever come across a privacy notice (Q1), whether they have ever adjusted their privacy preferences (Q2), how concerned they are about their data privacy (Q3), and how much control they feel over their online privacy (Q4).

A central part of our survey was a vignette section where participants imagined themselves using one of eight randomly assigned website types (news, e-commerce, search engine, social media, government, non-profit, entertainment, or a banking site). We used a between-subjects design, where everyone evaluated only one type of website category, and we had an equal number of participants evaluating each website category. Each vignette (i.e., website category) included a screenshot to mentally situate the participant in the environment of the website. These screenshots were non-branded, meaning that they did not represent real websites, so that participants would not be primed by their opinions of particular services. The website categories were compiled based on previous research by Habib et al. [38], Chanchary and Chiasson [13], and Amos et al. [5]. Participants were presented with one randomly selected vignette, but all survey questions and the evaluated data collection purposes were the same, regardless of the website category a participant was assigned to.

To gauge at whether certain consent-based purposes (*Functional and strictly necessary, UX improvements*, and *Sharing with third parties*) could potentially be included under legitimate interests, we asked participants how essential they deemed this purpose for the functioning and service offering of that particular kind of website (Q5, 7, 9). We used a 5-point likert-scale, ranging from "1 - Completely disagree" to "5 - Completely agree". We also asked participants to rate how much they think each purpose benefited different stakeholders (*the user, service provider, third party vendors, other users,* and *society*) (Q6, 8, 10) on a 4-point likert-scale, ranging from "1 - Not at all" to "4 - A lot".

From an operational point of view, the application of legitimate interest means that, for certain purposes, personal data is collected without the user's explicit permission. We investigated how our participants felt about this practice with respect to the purposes commonly used under legitimate interest (*Personalizing and measuring content, Personalizing and measuring ads, Analytics, Develop and improve products, Future innovations, Archiving, Security and debugging,* and *Fraud and law enforcement*), asking how comfortable they were with websites collecting data for these purposes without asking for user permission (Q11, 13, 15, 17, 19, 21, 23, 25). Additionally, we asked participants to rate on a 4-point likert-scale how much they think each purpose benefits different stakeholders (*the user, service provider, third party vendors, other users,* and *society*) (Q12, 14, 16, 18, 20, 22, 24, 26). In this part of the survey, we did not use the term "legitimate interest" because we anticipated that some participants might not understand it. Instead, we paraphrased it using an operational framing: "purposes that use data without your permission".

The next section of our survey investigated participants' general understanding of the concept of legitimate interest and its practical implications. Questions included: asking participants whose legitimate interests they thought websites were referring to when collecting data for a "legitimate interest" purpose (Q27), presenting screenshots of the four possible consent/legitimate interest toggle configurations and asking participants in which configuration(s) they thought data was being collected (Q28), as well as asking an open-ended question about the perceived harms of using legitimate interest for data collection (Q29).

The last section of the survey consisted of demographic questions. We asked about participants' technical and privacy knowledge using the web skills use survey (Q30-38) [39], their age (Q39), gender (Q40), how long they had been living in the EU (Q41), where they lived in the EU (Q42), and the language they primarily used the Internet in (Q43).

*4.1.2 Survey Validation.* We initially piloted the survey with three participants; one participant had a security and privacy background, and two had non-computational backgrounds. Based on the findings from our pilot, we revised the wording and presentation of the survey, and released a pre-test with 30 participants, which is a recommended sample size for survey validation [67]. We distributed the pre-test on Prolific [66][7], using the same pre-screening criteria as in the final survey. We did not use the pre-test data for our final analysis. The pre-test with 43 survey items had a Cronbach's alpha of $\alpha = 0.92$, which indicates that our survey had good internal reliability [74]. We therefore did not need to further change our questions.

To maximize the survey validity, we reused or adapted questions from previous studies where applicable. Some questions and multiple choice responses were adopted from previous work by Kozyreva et al. [47] (for the question, *How concerned are you about your data privacy when using the Internet?*). Habib et al.'s codebook was used to inform some multiple choice responses [38]. In the demographic section, we used the validated web skills use survey by Hargittai and Hseih [39]. We were also careful to ensure that there was a correspondence between the survey questions and our

[7] https://www.prolific.co/

research questions. For example, for *RQ3: What do people expect or think is reasonable for companies to collect under legitimate interest?* we asked, *Sometimes, websites might collect data for the following purposes without asking for permission. For [insert legitimate interest purpose], how comfortable are you with this?*

*4.1.3 Taxonomy of purposes.* There is no centralized nor standard list of legitimate interest purposes, as this legal basis is determined on a case-by-case basis with the legitimate interests balancing test [33, 64]. Accordingly, pursuant to our survey, we used the purposes from the Cookiepedia Database [8], which provides an extensive database and categorization of cookies, and is often used in empirical studies on cookies [41, 69]. Additionally, we looked to guidelines from the European Data Protection Board (EDPB) [19], Center for Information Policy Leadership (CIPL) [30], and the TCF [24] to find which purposes can be based on legitimate interest.

After several discussions, we agreed to survey participants on 11 purposes for section two of our survey - eight of which were based on legitimate interest (therefore not requiring consent), and three of which are subject to consent, but were interested in seeing if users might deem them essential, as potential legitimate interests. We were broadly interested in the legitimate interest purposes we identified from the first study, but also purposes related to the repurposing of data, such as *Future innovations, Archiving,* and *Product development* because of their relevance to critiques of data minimization [29, 79] and their general importance to scientific, social, and product development. For the three consent-based purposes, we included them because we they are commonly used purposes [40, 69], therefore we were interested to see if we could reduce user fatigue by including these as potential legitimate interests in the future.

For purposes that were very similar, such as TCF-based *Create a personalized ad profile, Select personalized ads, Create a personalized content profile,* and *Select personalized content* we amalgamated them into general purposes called *Personalized content delivery and measurement* and *Personalized ad delivery and measurement* to reduce repetition for participants. Below, we list the purposes and definitions we presented to participants. The table in Section 6 of our Supplementary Materials describes the reasoning behind each purpose and where we sourced it from.

- *Functional, strictly necessary purposes:* enables you to move around the website and use its features
- *User experience (UX) improvements*: collect and process information about your use of the website to provide you with personalized enhanced features, like to remember the choices that you made
- *Sharing data with third parties:* sharing your information with third-parties beyond the website you are visiting
- *Personalizing and measuring content:* create and display personalized content that is relevant to you, content you interact with are measured for performance and effectiveness
- *Personalizing and measuring ads:* deliver, personalize ads, select and measure the effectiveness of these ads. Advertising and marketing material can be shown to you based on the content you're viewing, the app you're using, your approximate location, or your device type. Ads you interact with are measured for performance and effectiveness
- *Analytics, statistics, and audience insights:* measure, improve and report on your engagement with the website service, like the number of unique visits to a website, how long users stay in the site, what parts and pages of the website are browsed, main searched keywords, etc. Apply market research to learn more about audiences who visit sites/apps and view ads
- *Developing and improving products:* Your data can be used to improve existing systems and software, and to develop new products and functionalities
- *Future innovations:* your data can be used for future innovations unrelated to the service the website currently provides
- *Archiving data for scientific or historical research, public interest, or statistical purposes:* your data can be used for future archiving purposes in the public interest, scientific or historical research purposes or statistical purposes
- *Security and debugging:* your data can be used to ensure systems are working properly and securely
- *Fraud detection and law enforcement:* your data can be used to monitor for and prevent fraudulent activity, and indicating possible criminal acts and threats to public safety.

*4.1.4 Participants.* For both the pre-test and final survey, we surveyed internet users who speak English and have been living in the EU for at least one year, as we wanted participants who have been exposed to the GDPR and cookie policies. We used Prolific [66] and recruited participants with a minimum approval rate of 90% on the platform to ensure high-quality answers. Our institutional review board declared that our study was exempt from federal human subjects regulation.

We conducted a power analysis to determine the sample size for our survey with 8 website category conditions. To achieve high (0.8) statistical power, we needed approximately 400 participants. Since participants were based in the EU, we expected all of them to have seen privacy notices. Yet, one participant said they had never encountered a privacy notice before, we therefore excluded them from the analysis. Participants were compensated 2,70€ in exchange for approximately 15 minutes of their time. From our observations during the pilot studies and median completion time from our pre-test survey, it was determined that 15 minutes was likely to be more than enough time to complete the survey.

In total, we analyzed 399 responses. We had 250 male, 145 female, and 4 non-binary participants. As is the case with most research using online crowdsourcing platforms, our participants were mostly young, with 76% being between 18 and 34 years old [42, 71]. Almost all (96.24%) had lived in the EU for over four years, and over half (54.14%) primarily used the internet in English.

## 4.2 Results

*4.2.1 User understandings of legitimate interest.* Our survey indicated that the majority of participants believe that, when data is collected for legitimate interest purposes, those are the legitimate interests of the service provider and third party vendors. However, a non-negligible number of respondents incorrectly believed that data was collected in the legitimate interest of themselves, other users, or society (see Table 2).

[8] https://cookiepedia.co.uk/classify-cookies

**Table 2: When a website tells you they are collecting data for "legitimate interest" purposes, whose legitimate interests do you think they mean? [Select all that apply]**

| User Group | Count |
|---|---|
| You (the user) | 64 |
| The company offering the service (service provider) | 367 |
| 3rd party vendors (e.g., advertisers) | 255 |
| Society | 46 |
| Other users of the service | 40 |
| Unsure | 26 |

**Table 3: "Under which scenarios do you think your data would be collected? [Select all that apply]"**

| Toggle Options | Count |
|---|---|
| Both toggles selected | 355 |
| Consent only selected | 249 |
| Legitimate interest only selected | 280 |
| No toggles selected | 56 |

When it comes to the consent/legitimate interest toggles present in privacy notices, most participants also tended to believe that data was being collected unless no toggles were selected, as seen in Table 3. Participants generally have a correct understanding of whom legitimate interests benefit the most and what happens in practice when consent and legitimated interest decision making is amalgamated, but there are some users whose beliefs are incorrect. This result shows that some users are likely making ill-informed decisions with regard to their data processing preferences.

**Table 4: User Evaluations of Legitimate Interest Purposes**

| Legitimate Interest Purpose | Mean | Median |
|---|---|---|
| Personalized content and measurement | 2.07 | 2 |
| Personalized ads and measurement | 1.80 | 2 |
| Analytics | 2.42 | 2 |
| Develop and improve products | 2.85 | 3 |
| Future innovations | 2.47 | 2 |
| Archiving data | 2.80 | 3 |
| Security and debugging | 3.17 | 3 |
| Fraud and law enforcement | 3.03 | 3 |

*4.2.2 User evaluations of legitimate interest data collection purposes.* For the eight legitimate interest purposes we tested, we aggregated our data across all website categories (see Table 4 for mean and median scores). Herein we found that *security and debugging*, and *fraud and law enforcement* were the most likely to be purposes for which users felt comfortable sharing data for without their permission. Wilcoxon signed-rank tests found that *security and debugging* and *fraud and law enforcement* were statistically significant with every single purpose except for each other ($Z = 84603, p = 0.15$). This confirms that users were more comfortable with these purposes compared to other purposes, but users' comfort with *security and debugging* and *fraud and law enforcement* did not differ significantly from each other.

*Personalized ad delivery and measurement* received the lowest levels of user comfort scores. Wilcoxon signed-rank tests confirmed that the *Personalized ad delivery and measurement* purpose was statistically significant with every legitimate interest purpose, therefore confirming that users felt the least comfortable with this purpose. Refer to Section 7 of the Supplementary Materials for detailed Wilcoxon test results. We found that users are not very comfortable with *develop and improve products*, *archiving data*, *future innovations*, *analytics*, and *personalized content and measurement*, but they are not viewed as negatively compared to *personalized ad delivery and measurement*. Figure 4 illustrates the user ratings for the legitimate interest purposes included in our study.

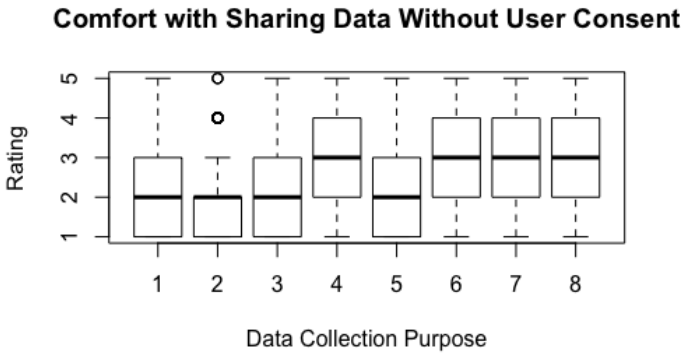



**Figure 4: User ratings of how comfortable they are when their data is collected without permission for the following purposes: 1) Personalizing and measuring content, 2) Personalizing and measuring ads, 3) Analytics, 4) Develop and improve products, 5) Future innovations, 6) Archiving, 7) Security and debugging, 8) Fraud and law enforcement. The box displays the median, first, and third quartiles, the dots represent outliers.**

**Table 5: User Evaluations of Potential Essential Purposes**

| Purpose | Mean Score | Median Score |
|---|---|---|
| Functional, strictly necessary | 3.9 | 4 |
| UX improvement | 3.02 | 3 |
| Sharing with third parties | 1.7 | 1 |

*4.2.3 Purposes deemed essential.* For the three consent-based purposes included in our survey, we found that participants found the *sharing with third parties* and *UX improvement* purposes the least essential, and *functional, strictly necessary* the most essential (see Table 5 for mean and median scores). Figure 5 illustrates user ratings for these purposes in our study. From this, we see that *functional, strictly necessary* purposes could potentially be included as a future legitimate interest purpose. We do not suggest *UX Improvements* or *Sharing with third parties* be legitimate interests due to low ratings.

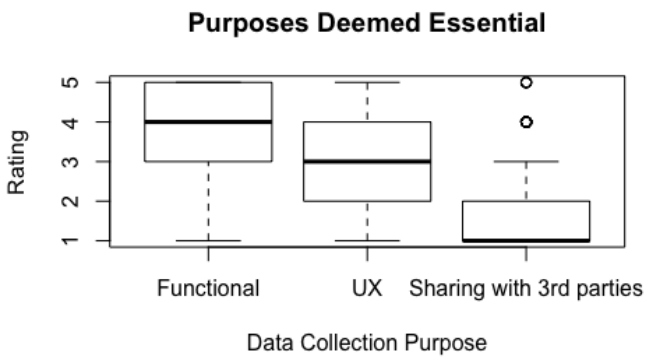



**Figure 5: User ratings of how much they deem the following purposes essential for the functioning of their given website category. The box displays the median, first, and third quartiles, the dots represent outliers.**

**Table 6: Regression Table of the Factors Impacting User Acceptance of a Data Collection Purpose**

| Variable | $\beta$ | $t$ | $p$ |
|---|---|---|---|
| Purpose benefits the user (themself) | 0.43 | 7.30 | < 0.001** |
| Purpose benefits society | 0.17 | 2.10 | 0.04* |
| Purpose benefits other users | 0.21 | 3.56 | < 0.001** |
| Purpose benefits service providers | -0.16 | -2.30 | 0.02* |
| Purpose benefits third party vendors | -0.19 | -3.32 | < 0.001** |
| Participant's knowledge of privacy settings | 0.04 | 0.80 | 0.43 |
| Participant's age | 0.01 | 0.18 | 0.86 |
| Participant's gender | 0.01 | 0.14 | 0.89 |

*4.2.4 Impacts on user acceptance of a data collection purpose.* We ran a multiple regression to see what impacts the user acceptance of a data collection purpose the most (see Table 6 for results). Here, we define *user acceptance* as how comfortable users are with sharing data for a specific purpose without their consent or how essential a purpose is judged to be. We found that user acceptance of a data collection purpose is impacted most by who the data collection purpose is believed to benefit, $F(58, 341) = 5.99, p < 0.001$, $R^2 = 0.50, R^2_{adjusted} = 0.42$. If users believed a purpose benefits themselves, society, or other users more, they are more likely to accept this purpose, regardless of their demographics or knowledge of privacy settings. However, if a purpose is believed to benefit service providers or third party vendors more, users are less likely to be accepting of this purpose.

*4.2.5 Some website categories impact how some data collection purposes are evaluated.* Due to our data being likert-scale, we ran one-way Kruskal-Wallis tests for the different data collection purposes to check whether website category impacts user acceptance of the 11 purposes.

We found significant results for *functional and strictly necessary* ($H(7) = 19.32, p = 0.007$) and *sharing data with third parties* purposes ($H(7) = 17.14, p = 0.02$). After identifying purposes where there were significant effects, we ran Dunn's post-hoc tests to identify which website categories were impacted.

The category a website belongs to impacts user opinions of how legitimate interest purposes are used to some extent, but only for news, search engine, and banking websites, and for certain purposes only. Participants found *functional and strictly necessary* purposes more essential for search engine ($p = 0.04$) and banking sites ($p = 0.01$) compared to news sites. Additionally, participants found *sharing data with third parties* to be significantly less essential for banking sites compared to search engine ($p = 0.02$) and news websites ($p = 0.01$). This is a similar finding to previous research which found that users were most concerned about third party tracking on banking sites compared to other kinds of sites [13].

*4.2.6 Harms associated with legitimate interest data collection.* We introduced an open-ended question in our survey asking participants what harms they believed were associated with data collection for legitimate interest purposes. With these responses, we conducted a qualitative analysis to identify the harms participants mentioned.

Table 7 lists these identified harms, and how often they came up; we explain the meaning of these harms, along with example quotes from participants. In total, we received 457 different responses because some participants listed down several harms. Since this is a qualitative analysis, it is possible that some harms may overlap.

## 4.3 Demographic Effects

In this section, we ran Spearman correlations between various demographic factors with user acceptance ratings for data collection purposes, and general privacy behaviours. To avoid spurious correlations, we used a Bonferroni correction [49].

*4.3.1 The effect of privacy settings knowledge.* A participant's privacy settings knowledge was determined by what they rated themselves for their knowledge of privacy settings in the web skills use survey. We found that those with more privacy settings knowledge were more likely to adjust their privacy preferences in privacy notices ($r(397) = -0.18, p < 0.001$), and more likely to feel concerned about their data privacy ($r(397) = 0.17, p = 0.001$). We did not find any significant correlations between privacy settings knowledge and user acceptance of any data collection purposes.

*4.3.2 Age.* We found that age has no correlation with whether one modifies their privacy settings in privacy notices, how concerned they claimed to be about their data privacy, or how much control they feel over their data. However, we found that compared to older individuals, younger individuals are more comfortable with certain purposes being used for data collection. Younger individuals are more comfortable with *personalized content delivery and measurement* ($r(397) = -0.14, p = 0.007$), *personalized ad delivery and measurement* ($r(397) = -0.13, p = 0.008$), *developing and improving products* ($r(397) = -0.11, p = 0.02$), *future innovations* ($r(397) = -0.12, p = 0.02$), *security and debugging* ($r(397) = -0.12, p = 0.02$), and *fraud detection and law enforcement* purposes ($r(397) = -0.12, p = 0.02$).

*4.3.3 Gender.* There were no correlations between gender and whether one changes their privacy settings, or their concern over their data privacy. However, we found that women were more

**Table 7: Potential Harms of Legitimate Interest According to Users**

| Harm | Prevalence | Participant Quote |
|---|---|---|
| *Unwanted advertising:* Users are concerned about their data being used for profiling, or just being collected to send them unwanted ads. | 16.4% (out of 457 responses) | "Being profiled and getting targeted ads that uses personal data for benchmarking and displaying relevant ads that people don't want" |
| *Data breach:* Concerns that if companies that have their data are the victim of a security attack, their data will be compromised. | 28.5% | "Companies could be hacked, my personal data could be leaked or easily accessed by someone else" |
| *Privacy concerns:* General beliefs about how data collection infringes on one's privacy. | 20.6% | "The lack of privacy, as your habits and likes can be easily tracked" |
| *Misuse of data:* Beliefs that companies that have access of one's data may sell their data, or use it for nefarious reasons. | 15.6% | "Companies could sell data to government or terrorist organizations" |
| *Loss of control:* There is a lack of transparency in what happens to user data once they give it away, therefore users are concerned about who has access, and what it is being used for. | 11.5% | "I have no control over what companies are holding information on me and what it is being used for, parties are profiting from my information with no compensation to me" |
| *Manipulation of users:* Users have an understanding that data can be used for personalizing content and advertisements, and view it as something that can influence them. | 6% | "Isolating users in thought bubbles and making different parts of society unable to coexist peacefully" |
| *Are not worried* | 0.02% | "I see no serious damage, I have nothing to hide." |
| *Unsure* | 1% | |

likely than other genders to feel like they had less control over the data that is collected from them online ($r(397) = 0.14, p = 0.006$). Compared to other genders, men were generally more comfortable with certain purposes being used for data collection such as: *personalized content delivery and measurement* ($r(397) = -0.12, p = 0.02$), *analytics, statistics and audience insights* ($r(397) = -0.14, p = 0.005$), *future innovations* ($r(397) = -0.15, p = 0.004$), *archiving data* ($r(397) = -0.10, p = 0.04$), and *security and debugging* purposes ($r(397) = -0.14, p = 0.005$).

## 5 LIMITATIONS

In our web crawl, we removed websites that were not in English for our analysis, and only analyzed English privacy notices. As a result, our results may not be generalizable to all languages spoken in the EU. Additionally, we ran our crawler back in May 2022, and the internet is constantly updating and changing, therefore we may not capture all the recent updates made to privacy notices.

In study two, participants were generally younger, which is commonly seen in studies using online crowdsourcing [42, 71], therefore our results may not be reflective of how the general population feels about various data collection purposes. To ensure that we got a sufficient number of responses to the open-ended harms question (outlined in Section 4.2.6, we made the question obligatory. Therefore, the proportion of users who claim to be unsure of the harms of legitimate interest may underrepresented in our results. Additionally, we note that the harms participants mentioned might not be specific to legitimate interest-based data collection, but rather to data collection more generally – as we found in Section 4.2.1, not all participants have an accurate understanding of legitimate interest.

It is also possible that because users are not always aware of the various data collection purposes used to collect their data, some purposes we presented could have been misunderstood by our participants. We tried mitigating this by including user-friendly texts for each purpose, but participants could have skimmed our definitions and based their judgements on what they *think* they know about a given purpose.

## 6 DISCUSSION

*Study one* identified how legitimate interest is being used in practice, and *study two* investigated how users perceive these practices. In this section we discuss the most pertinent results and their implications. Our findings indicate that we must not only work towards making data processing under legitimate interests more transparent for users, but also that we must improve the surrounding design practices so as to incentivize user engagement with legitimate interest preference mechanisms.

**The use of legitimate interest is exploited through deceptive design practices both at UI and linguistic levels.** From our findings, we noticed that the implementation of this legal ground has many UI and linguistic deceptive design elements so far unreported in the literature of deceptive designs. In particular, more attention should be paid to deceptive designs that go beyond the UI. Complex deceptive designs often combine multiple dubious practices in one interface [15], as our study found with linguistic and UI deceptive designs being used when presenting legitimate interest. Section 6.1 outlines the deceptive designs we identified in more detail.

**Legitimate interest deceptive designs may be intentional.** We believe that legitimate interests might be purposefully designed in a way to limit user interactions with these purposes so that

websites and CMPs can collect as much user data as possible, and therefore receive more revenue. Several findings from Study 1 support this position. Firstly, only 4.74% of the top 10,000 websites mention "legitimate interest(s)" in their privacy notices; presumably, many more sites are using this legal basis without disclosing it to users. Secondly, it is difficult to object to legitimate interests, as 42.41% of sites only mention legitimate interest in the second layer of a privacy notice. Thirdly, 31% of sites included a legally dubious consent/legitimate interest toggle. Lastly, several sites required users to object individually to legitimate interest purposes and vendors. These design elements are problematic because they will likely lead to low user interaction rates. A study by Hils et al. showed that only 1.3% of privacy notice interactions involved adjusting toggles to consent to specific vendors/purposes, and most user interactions occur only in the first layer of a privacy notice [40, 55, 75, 76].

**IAB Europe's TCF has a major impact on how legitimate interest is applied in practice.** Notwithstanding several legitimate interest-related requirements and guidelines (see Section 2.1), we only saw the TCF's legitimate interests purposes being implemented in practice. Notably, websites continue to use the TCF even after this framework was declared to breach the GDPR by using unlawful practices and for collecting data for advertising purposes on the ground of legitimate interests in February 2022 [6, 77]. In September 2022, the TCF was brought to the highest court of the EU (European Court of Justice). [9]

This shows the impact of the TCF in how legitimate interest is implemented in practice and the lack of enforcement to ensure TCF adheres to the legal standard. We noticed that the way TCF-based CMPs implemented privacy notices differed in terms of their design: some CMPs use more deceptive designs than others, which has been reflected in previous research [60]. Since CMPs provide websites design templates for privacy notices at scale, it is important that this market segment is monitored [60, 69].

**Users are not fully aware of which legal basis data is being collected on, who is collecting data, or whom it benefits.** Users tended to believe that i) legitimate interests benefit service providers and/or third party vendors, and ii) their data was being collected when both or at least one (consent or legitimate interest) toggle was selected in the privacy notice. Even though our findings show that the majority of participants were correct in their assessments, they also highlight that a non-negligible number of users have ill-informed beliefs about legitimate interests. Thus, a question arises of whether all users can object to legitimate interests in an informed manner, especially since legitimate interests are often not disclosed to users in privacy notices or meaningfully explained. The way the legal basis is used might in particular not be transparent to users without a legal background who rely on commonsense understanding of the term "legitimate" and their own intuitions about whose "interests" are being considered.

**Users are not fond of personalization nor advertising purposes, despite how often these are used in practice.** Overall, the purposes of *personalized ad delivery and measurement* and *personalized content delivery and measurement* received low scores from users, which is at odds with how often personalization purposes are used in practice. However, *personalized content delivery and measurement* was more acceptable to users compared to advertising purposes. This indicates that users may not view personalization as neutral, but instead view it as harmful, as 6% of the identified harms had to do with how personalization could be used to manipulate users. Moreover, data collection purposes often group personalized ads and content together, but our study found that users evaluate personalized content and personalized ads differently, echoing previous findings [13, 47]. Many websites listed several advertising purposes as their legitimate interests, a practice which users tend to disapprove of according to our results, and is illegal [63].

**User acceptance of a data purpose is impacted most by whom it is believed to benefit.** We found that users tend to think most data collection purposes benefit service providers and third party vendors. There were some variations in user acceptance for some purposes, such as *fraud and law enforcement* being judged to benefit all user groups more equally. We found that the biggest impact on user acceptance of a data purpose is who users believe it is judged to benefit, regardless of user demographics or privacy knowledge. If a purpose is judged to benefit the users themselves, other users, and/or society more than the service provider and/or third party vendor, then there is more user acceptance for data processing.

## 6.1 Deceptive Design Elements

We describe the legitimate interest-related deceptive designs identified in our study using existing privacy deceptive design taxonomies which were identified by Bosch et al. [10] and Brignull [12], as well as describing other deceptive designs not previously covered in the literature. Deceptive designs we identified that were previously described by Bosch et al. included *maximize, centralize,* and *obscure* [10]. Deceptive designs we identified that were previously described by Brignull included *roach motel* [12] (also called *false hierarchy*) [15]. We also additionally identified the deceptive designs of *complex choice architecture*, and *misleading terminology*.

**Maximize** means to collect as much personal data as possible—more than what is needed for the task [10]. This deceptive design was exemplified by the following: i) each purpose can only have one legal basis, but our results show that 31% of sites have purposes in privacy notices that rely on both legal bases (consent and legitimate interest); ii) legitimate interest-based purposes and/or vendors were often pre-selected as a default (in privacy notices that allow users to object); iii) objecting to legitimate interests can be complicated, as it sometimes requires users to individually opt out by purpose and/or vendor, or go through multiple layers of a privacy notice to object.

**Centralize** refers to when personal data is "collected, stored, or processed at a central entity" [10]. With the presence of various adtech companies and CMPs embedding the TCF, we noticed that most of the same TCF-based CMPs collected data from users across multiple websites.

**Obscure** means to make it difficult for data subjects to know how their personal data is being collected and used by data controllers [10]. In our analysis, we found that "legitimate interest" is only mentioned in 474 (4.74%) out of the 10,000 websites we analyzed, therefore

[9] https://www.dataprotectionauthority.be/iab-europe-case-the-market-court-refers-preliminary-questions-to-the-court-of-justice-of-the-eu

many users are probably unaware that legitimate interests are being used to collect data without their consent. Only 86% of sites disclosed that they collect data under legitimate interest grounds in their privacy notices, but not all sites allowed users to object to such processing easily.

**Roach motel**, also referred to as a *false hierarchy* [15], are deceptive designs where it is easy for users to enter into a situation, but it is difficult to get out of it [12]. While it is easy for users to accept all purposes, objecting to legitimate interests and managing one's choices after accepting is much more difficult.

The GDPR requires an *opt-in* consent approach, where users manually opt into purposes/vendors they want to consent to when they make their granular consent choices [2]. However, such a rule is not explicitly required for legitimate interest, which is often managed in an *opt-out* manner. Users then need to manually opt out of pre-selected purposes/vendors they do not want to share data with. Such an approach is not effective for reverting preferences for data collection because users tend to not adjust their privacy settings once the defaults have been selected [10, 51].

As mentioned in Section 2.1, practices related to unbalanced choices in privacy notices were deemed illegal and the companies implementing them were fined by DPAs. The same reasoning regarding balanced choices applies to legitimate interest settings (i.e., objecting to such purposes should be as easy as it is to accept or reject consent) and reflects the principle of data protection by design (Art. 25 GDPR).

In addition to the privacy deceptive design patterns identified using previous taxonomies, we also identified two other deceptive design patterns related to legitimate interests:

**Complex choice architecture.** This term describes a choice architecture that is complicated, therefore confusing to users and/or obscuring information, whether intentionally or accidentally. We found that legitimate interest elements in privacy notices contain many complex choice architectures. Examples include i) legally dubious toggles that rely on both consent and legitimate interests, therefore introducing complex decision making logic, ii) mentioning their respective legitimate interests in deeper layers of a privacy notice, therefore obscuring information, and iii) requiring users to manually opt out of individual vendors and/or purposes, therefore flooding users with multiple decision choices.

**Vague terminology.** The term "legitimate interest" is used in a vague and ambiguous way in practice. This has created a huge margin of interpretation that is, as our studies show, exploited to the detriment of data subjects' rights. In Article 6(1)(f) GDPR, "legitimate interests" are referred to as the *"legitimate interests pursued by the controller or by a third party"*, yet none of the privacy notices we analyzed used this wording.

The term "legitimate interest" by itself is vague, and we anticipate that many users will not understand whose legitimate interests are being considered. Additionally, describing data processing purposes as "legitimate" implies that these purposes are authentic, or justified, which may not always be the case. This is especially problematic because our analysis indicated that most companies provided unhelpful explanations of legitimate interest that do not explain what it means, and that only 86.3% of privacy notices listed the purposes that relied on legitimate interest. The fact that privacy notices do not mention what legitimate interest is could violate the requirement that the interests pursued by data controllers must be clearly articulated and transparent [19]. Also, if purposes are not listed, this might violate the GDPR transparency principle, and might constitute a violation of the legal requirement of specificity and explicitness that demand purposes to be detailed and precise and entail a shared common understanding, irrespective of any different cultural/linguistic backgrounds, level of understanding or special needs [19].

## 6.2 Implications

Our studies seem to indicate several areas of lack of enforcement around the legal basis of "legitimate interests". Here, we add legal and design implications drawn from our study to put our results into practice.

**Neither participants nor the law approve of advertising purposes under the legitimate interests legal basis, despite its common usage.** As observed in Section 2.1, the use of the open-textured term of "legitimate interests" allows controllers to base the processing of personal data on a balancing decision when indeed their own legitimate interests outweigh those of the data subjects. This is necessary because the law (Art. 6(1) GDPR) may not foresee all potential scenarios that may occur in practice.

"Legitimate interests" *is essential to ensure the processing of personal data in cases where these legitimate interests are likewise to be protected as fundamental rights.* However, as outlined above in Section 2.1, advertising does not constitute a legitimate interest. Online behavioural advertising (and consequent profiling of data subjects) is often used to finance online services and data collection for advertising is not "strictly necessary" from the point of view of a website user. Hence this purpose instead requires the legal basis of consent according to Art. 5(3) ePD, as mentioned in other studies [54, 58]. Several policy documents [26, 27, 65] and regulatory decisions [6] postulated this stance that advertising purposes should only rely on the legal basis of consent and not under legitimate interest.

The results of our second study showed that participants' evaluations of legitimate interests are well in line with this legal assessment as they do not approve of ad-related purposes. In contrast, our first study found that a lot of websites based their data processing on legitimate interests for advertising purposes. This result clearly points to a lack of enforcement and a mismatch between user preferences and reality regarding this legal basis.

**Lack of enforcement.** The function of "legitimate interests" as a legal basis for cases that were not foreseen by the law has one important consequence: the decision on whether legitimate interests actually outweigh the protection of personal data, and thus are a valid legal basis, is reliant on the case-by-case assessment of executive decisions by DPAs and judicial findings of courts. This means that this huge margin of interpretation ultimately depends on assessing these cases in practice. Otherwise, as our studies show, it may be exploited to the detriment of data subjects' rights. With all this flexibility of the term comes the concern that too many non-compliant cases occur in practice. Our results suggest that this is the point we have now reached, which is that there is effectively a lack of enforcement of legitimate interests in privacy notices. The 29WP already asserted that the lack of a consistent approach of this legal basis may result in a lack of legal certainty and predictability, may weaken the position of data subjects, and may

also impose unnecessary regulatory burdens on businesses [19]. Such inconsistencies have already led to litigation before the Court of Justice of the European Union [1, 16, 17].

Data Protection Authorities need to explicitly assert in their guidelines and decisions that balanced (or parity) choices (e.g., accept and object to all buttons, reducing the number of clicks, etc.) apply to legitimate interest-based settings as well, not only to consent settings. DPAs should also closely monitor the current practices of CMPs, since we find that these embed and disseminate, by default, deceptive practices in the privacy notices presented in thousands of websites. In particular, the adoption of guidelines, for example, by the EDPB that specify concrete requirements for the design in case of legitimate interests-based data processing, would be an important step. While these exist for the balancing test itself with Working Paper 217 [19], and on deceptive designs with the EDPB Guidelines on Dark Patterns 3/2022 [9], the cases where deceptive designs are used when legitimate interests are applied as a ground for data processing has not been addressed specifically. Our studies indicate that it is this combination that poses specific risks and that are in fact exploited by data controllers.

**Privacy by design recommendations.** Art. 25(1) of the GDPR requires data controllers to implement appropriate technical and organisational measures designed to implement data protection by design and by default. As it has been raised by the EDPB Guidelines on Dark Patterns, it would be important to strengthen and further specify ex-ante requirements for both the design of data processing mechanisms focusing on the UI and the language of privacy notices [9, p. 10-11]. Along with previous findings [40, 51, 53, 60, 70], we suggest that possible implementations of the principle of data protection by design and by default (Art. 25 GDPR) could include i) legitimate interest object-all buttons, ii) presenting fewer choices to prevent overwhelming users, and iii) adopting intelligible language within legitimate interest settings using neutral language.

Along these lines, Art. 10 of the Proposal of the ePrivacy Regulation (EU Commission version) [23] envisions the possibility for consent to be expressed at the browser level. This change, if accepted, would reduce the amount of privacy notices and deceptive design practices mentioned in this paper. The results of the trilogue negotiations—currently taking place between representatives of the three bodies involved in the EU legislative process, the EU Commission, the Parliament and the Council of Ministers—might dictate the future of consent expression, though we posit that mechanisms for automated consent have the potential to address deceptive design practices.

## 7 CONCLUSION

Legitimate interest is a broad legal ground for collecting data that has the potential for being misused to collect more user data. Our paper empirically investigates how legitimate interest is used in practice using a web crawl of 10,000 top websites, and investigates user perceptions of these practices. In our first study, we identified the various deceptive design patterns that are being used when implementing legitimate interest in practice. Our second study found that the way legitimate interest is used is not in line with user opinions of how they prefer their data be used, and that user acceptance of a data purpose is impacted by who it is believed to benefit.

Based on the results, we identify deceptive designs being used when implementing legitimate interests in privacy notices, and discuss the legal and design implications. Our studies indicate a need for better enforcement of the GDPR, reconsidering the way legitimate interests should be used, and consulting with end-users to integrate user opinions about how their data should be collected and used.

## 8 ACKNOWLEDGEMENTS

We would like to thank Michèle Finck, Frederik J. Zuiderveen Borgesius, attendees of the Max Planck Law-Tech Symposium, and UC Berkeley's Comparing Effects of and Responses to the GDPR and CCPA/CPRA Symposium for the discussions and providing us with helpful feedback for our paper.

# REFERENCES


[1] Judgment in Case C-131/12 Google Spain SL and Google Inc. v Agencia Española de Protección de Datos (AEPD) and Mario Costeja González, 2014. ECLI:EU:C:2014:317.

[2] Judgment in Case C-673/17 Bundesverband der Verbraucherzentralen und Verbraucherverbände – Verbraucherzentrale Bundesverband eV v Planet49 GmbH, 2019. http://curia.europa.eu/juris/documents.jsf?num=C-673/17.

[3] Deliberation of the restricted committee No. SAN-2021-023 of 31 December 2021 concerning GOOGLE LLC and GOOGLE IRELAND LIMITED, 2021. https://www.cnil.fr/sites/default/files/atoms/files/deliberation_of_the_restricted_committee_no._san-2021-023_of_31_december_2021_concerning_google_llc_and_google_ireland_limited.pdf.

[4] Deliberation of the restricted committee No. SAN-2021-024 of 31 December 2021 concerning FACEBOOK IRELAND LIMITED, 2022. https://www.cnil.fr/sites/default/files/atoms/files/deliberation_of_the_restricted_committee_no._san-2021-024_of_31_december_2021_concerning_facebook_ireland_limited.pdf.

[5] Ryan Amos, Gunes Acar, Eli Lucherini, Mihir Kshirsagar, Arvind Narayanan, and Jonathan Mayer. Privacy policies over time: Curation and analysis of a million-document dataset. In *Proceedings of the Web Conference 2021*, pages 2165–2176, 2021.

[6] Decision on the merits 21/2022 of 2 February 2022 Complaint relating to Transparency & Consent Framework, 2022.

[7] Brooke Auxier, Lee Rainie, Monica Anderson, Andrew Perrin, Madhu Kumar, and Erica Turner. Americans and privacy: Concerned, confused and feeling lack of control over their personal information. 2019.

[8] Adrien Barton and Till Grüne-Yanoff. From libertarian paternalism to nudging—and beyond. *Review of Philosophy and Psychology*, 6(3):341–359, 2015.

[9] European Data Protection Board. Dark patterns in social media platform interfaces: How to recognise and avoid them. Available at https://edpb.europa.eu/system/files/2022-03/edpb_03-2022_guidelines_on_dark_patterns_in_social_media_platform_interfaces_en.pdf (2022/03/14).

[10] Christoph Bösch, Benjamin Erb, Frank Kargl, Henning Kopp, and Stefan Pfattheicher. Tales from the dark side: Privacy dark strategies and privacy dark patterns. *Proc. Priv. Enhancing Technol.*, 2016(4):237–254, 2016.

[11] David M. Boush, Marian Friestad, and Peter Wright. *Deception in the Marketplace: The Psychology of Deceptive Persuasion and Consumer Self-Protection.* Rouledge, 2009.

[12] Harry Brignull. Deceptive design. https://www.deceptive.design/. Accessed: 2022-07-08.

[13] Farah Chanchary and Sonia Chiasson. User perceptions of sharing, advertising, and tracking. In *Eleventh Symposium On Usable Privacy and Security (SOUPS 2015)*, pages 53–67, 2015.

[14] European Commission. 2018 Reform of EU data protection rules. Available at https://ec.europa.eu/commission/sites/beta-political/files/data-protection-factsheet-changes_en.pdf (2018/05/25).

[15] European Commission, Directorate-General for Justice, Consumers, F Lupiáñez-Villanueva, A Boluda, F Bogliacino, G Liva, L Lechardoy, and T Rodríguez de las Heras Ballell. *Behavioural study on unfair commercial practices in the digital environment: Dark patterns and manipulative personalisation: Final report.* Publications Office of the European Union, 2022.

[16] Court of Justice of the European Union. Judgment in Case C-40/17 Fashion ID GmbH and Co.KG v Verbraucherzentrale NRW eV, 2019. ECLI:EU:C:2019:629.

[17] Court of Justice of the European Union. Request for a preliminary ruling Case C-17/22, 2022. https://curia.europa.eu/juris/showPdf.jsf?text=&docid=255645&pageIndex=0&doclang=EN&mode=lst&dir=&occ=first&part=1&cid=6693245.

[18] Dutch DPA. Dutch DPA guidance on legitimate interest, 2019. https://autoriteitpersoonsgegevens.nl/sites/default/files/atoms/files/normuitleg_gerechtvaardigd_belang.pdf.

[19] European Data Protection Board (EDPB). Opinion 06/2014 on the notion of legitimate interests of the data controller under Article 7 of Directive 95/46/EC (WP 217). https://ec.europa.eu/justice/article-29/documentation/opinion-recommendation/files/2014/wp217_en.pdf.

[20] Malin Eiband, Daniel Buschek, Alexander Kremer, and Heinrich Hussmann. The impact of placebic explanations on trust in intelligent systems. In *Extended abstracts of the 2019 CHI Conference on Human Factors in Computing Systems*, pages 1–6, 2019.

[21] Pardis Emami-Naeini, Henry Dixon, Yuvraj Agarwal, and Lorrie Faith Cranor. Exploring how privacy and security factor into IoT device purchase behavior. In *Proceedings of the 2019 CHI Conference on Human Factors in Computing Systems*, pages 1–12, 2019.

[22] Directive 2009/136/EC of the European Parliament and of the Council, 2009. https://eur-lex.europa.eu/LexUriServ/LexUriServ.do?uri=OJ:L:2009:337:0011:0036:En:PDF.

[23] Proposal for a Regulation of the European Parliament and of the Council concerning the respect for private life and the protection of personal data in electronic communications and repealing Directive 2002/58/EC (Regulation on Privacy and Electronic Communications), 2017. https://eur-lex.europa.eu/LexUriServ/LexUriServ.do?uri=OJ:L:2009:337:0011:0036:En:PDF.

[24] Internet Advertising Bureau (IAB) Europe. What is the Transparency & Consent Framework (TCF)? Available at https://iabeurope.eu/transparency-consent-framework/ (2019/08/21).

[25] European Commission. Letter to the Dutch DPA on legitimate interests, 2022. https://static.nrc.nl/2022/pdf/letter-dutch-dpa-legitimate-interest.pdf.

[26] European Data Protection Board (EDPB). Guidelines 2/2019 on the processing of personal data under article 6(1)(b) gdpr in the context of the provision of online services to data subjects.

[27] European Data Protection Board (EDPB). Opinion 2/2010 on online behavioural advertising, 22 june 2010, WP171, p. 10.

[28] Federico Ferretti. Data protection and the legitimate interest of data controllers: Much ado about nothing or the winter of rights? *Common Market Law Review*, 51(3), 2014.

[29] Michèle Finck and Asia Biega. Reviving purpose limitation and data minimisation in personalisation, profiling and decision-making systems. *arXiv preprint arXiv:2101.06203*, 2021.

[30] Centre for Information Policy Leadership. Recommendations for implementing transparency, consent and legitimate interest under the gdpr. Available at https://www.informationpolicycentre.com/uploads/5/7/1/0/57104281/cipl_recommendations_on_transparency_consent_and_legitimate_interest_under_the_gdpr_-19_may_2017-c.pdf (2017/05/19).

[31] Centre for Informational Policy Leadership. Recommendations for implementing transparency, consent and legitimate interest under the GDPR. *Centre for Information Policy Leadership GDPR Implementation Project*, 2017.

[32] Forbrukerradet. Deceived by design: How tech companies use dark patterns to discourage us from exercising our rights to privacy. https://fil.forbrukerradet.no/wp-content/uploads/2018/06/2018-06-27-deceived-by-design-final.pdf, 2018. Accessed: 2022-03-30.

[33] Elena Gil González and Paul De Hert. Understanding the legal provisions that allow processing and profiling of personal data—an analysis of GDPR provisions and principles. In *Era Forum*, volume 19, pages 597–621. Springer, 2019.

[34] PAJ Graßl, HK Schraffenberger, FJ Zuiderveen Borgesius, and MA Buijzen. Dark and bright patterns in cookie consent requests. 2021.

[35] Colin M Gray, Yubo Kou, Bryan Battles, Joseph Hoggatt, and Austin L Toombs. The dark (patterns) side of UX design. In *Proceedings of the 2018 CHI Conference on Human Factors in Computing Systems*, pages 1–14, 2018.

[36] Colin M. Gray, Cristiana Santos, Nataliia Bielova, Michael Toth, and Damian Clifford. Dark patterns and the legal requirements of consent banners: An interaction criticism perspective. In *Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems*, CHI '21, New York, NY, USA, 2021. Association for Computing Machinery.

[37] Hana Habib, Megan Li, Ellie Young, and Lorrie Cranor. "Okay, whatever": An Evaluation of Cookie Consent Interfaces. In *CHI Conference on Human Factors in Computing Systems*, pages 1–27, 2022.

[38] Hana Habib, Sarah Pearman, Jiamin Wang, Yixin Zou, Alessandro Acquisti, Lorrie Faith Cranor, Norman Sadeh, and Florian Schaub. "It's a scavenger hunt": Usability of websites' opt-out and data deletion choices. In *Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems*, pages 1–12, 2020.

[39] Eszter Hargittai and Yuli Patrick Hsieh. Succinct survey measures of web-use skills. *Social Science Computer Review*, 30(1):95–107, 2012.

[40] Maximilian Hils, Daniel W Woods, and Rainer Böhme. Measuring the emergence of consent management on the web. In *Proceedings of the ACM Internet Measurement Conference*, pages 317–332, 2020.

[41] Xuehui Hu, Nishanth Sastry, and Mainack Mondal. CCCC: Corralling cookies into categories with CookieMonster. In *13th ACM Web Science Conference 2021*, pages 234–242, 2021.

[42] Panagiotis G Ipeirotis. Demographics of Mechanical Turk. 2010.

[43] Eric J Johnson, Suzanne B Shu, Benedict GC Dellaert, Craig Fox, Daniel G Goldstein, Gerald Häubl, Richard P Larrick, John W Payne, Ellen Peters, David Schkade, et al. Beyond nudges: Tools of a choice architecture. *Marketing letters*, 23(2):487–504, 2012.

[44] Irene Kamara and Paul De Hert. Understanding the balancing act behind the legitimate interest of the controller ground: A pragmatic approach. *Brussels Privacy Hub*, 4(12), 2018.

[45] Konrad Kollnig, Reuben Binns, Max Van Kleek, Ulrik Lyngs, Jun Zhao, Claudine Tinsman, and Nigel Shadbolt. Before and after gdpr: tracking in mobile apps. *arXiv preprint arXiv:2112.11117*, 2021.

[46] Konrad Kollnig, Pierre Dewitte, Max Van Kleek, Ge Wang, Daniel Omeiza, Helena Webb, and Nigel Shadbolt. A fait accompli? an empirical study into the absence of consent to {Third-Party} tracking in android apps. In *Seventeenth Symposium on Usable Privacy and Security (SOUPS 2021)*, pages 181–196, 2021.

[47] Anastasia Kozyreva, Philipp Lorenz-Spreen, Ralph Hertwig, Stephan Lewandowsky, and Stefan M Herzog. Public attitudes towards algorithmic personalization and use of personal data online: Evidence from Germany, Great Britain, and the United States. *Humanities and Social Sciences Communications*, 8(1):1–11, 2021.

[48] Oksana Kulyk, Annika Hilt, Nina Gerber, and Melanie Volkamer. "This website uses cookies": Users' perceptions and reactions to the cookie disclaimer. In *European Workshop on Usable Security (EuroUSEC)*, volume 4, 2018.

[49] Sangseok Lee and Dong Kyu Lee. What is the proper way to apply the multiple comparison test? *Korean Journal of Anesthesiology*, 71(5):353–360, 2018.

[50] Luxembourg DPA. Decision regarding amazon europe core s.À rl, 2021. https://cnpd.public.lu/fr/actualites/international/2021/08/decision-amazon-2.html.

[51] Dominique Machuletz and Rainer Böhme. Multiple purposes, multiple problems: A user study of consent dialogs after GDPR. *Proceedings on Privacy Enhancing Technologies*, page 481–498, 2020.

[52] Arunesh Mathur, Gunes Acar, Michael J Friedman, Eli Lucherini, Jonathan Mayer, Marshini Chetty, and Arvind Narayanan. Dark patterns at scale: Findings from a crawl of 11k shopping websites. *Proceedings of the ACM on Human-Computer Interaction*, 3(CSCW):1–32, 2019.

[53] Célestin Matte, Nataliia Bielova, and Cristiana Santos. Do cookie banners respect my choice?: Measuring legal compliance of banners from IAB Europe's Transparency and Consent Framework. In *2020 IEEE Symposium on Security and Privacy (SP)*, pages 791–809. IEEE, 2020.

[54] Célestin Matte, Cristiana Santos, and Nataliia Bielova. Purposes in IAB Europe's TCF: Which legal basis and how are they used by advertisers? In *Annual Privacy Forum*, pages 163–185. Springer, 2020.

[55] Aleecia M. McDonald and Lorrie Faith Cranor. The cost of reading privacy policies. *Journal of Law and Policy for the Information Society*, 2009.

[56] Nora McDonald, Sarita Schoenebeck, and Andrea Forte. Reliability and inter-rater reliability in qualitative research: Norms and guidelines for CSCW and HCI practice. *Proceedings of the ACM on Human-Computer Interaction*, 3(CSCW):1–23, 2019.

[57] Mary L McHugh. Interrater reliability: the kappa statistic. *Biochemia medica*, 22(3):276–282, 2012.

[58] Victor Morel, Cristiana Santos, Yvonne Lintao, and Soheil Human. Your consent is worth 75 euros a year - measurement and lawfulness of cookie paywalls. In *Proceedings of the 21st Workshop on Privacy in the Electronic Society*, WPES'22, page 213–218, New York, NY, USA, 2022. Association for Computing Machinery.

[59] Arvind Narayanan, Arunesh Mathur, Marshini Chetty, and Mihir Kshirsagar. Dark patterns: Past, present, and future: The evolution of tricky user interfaces. *Queue*, 18(2):67–92, 2020.

[60] Midas Nouwens, Ilaria Liccardi, Michael Veale, David Karger, and Lalana Kagal. Dark patterns after the GDPR: Scraping consent pop-ups and demonstrating their influence. In *Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems*, pages 1–13, 2020.

[61] Regulation of the European Parliament and of the Council on a Single Market For Digital Services (Digital Services Act). Com(2020) 825 final, 2022.

[62] European Union: Council of the European Union. The Charter of Fundamental Rights of the European Union (2007/C 303/01), C 303/1.

[63] Information Commissioner's Office. Update report into adtech and real time bidding. Available at https://ico.org.uk/media/about-the-ico/documents/2615156/adtech-real-time-bidding-report-201906-dl191220.pdf (2019/06/20).

[64] Information Commissioner's Office. What is the 'legitimate interests' basis? https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/legitimate-interests/what-is-the-legitimate-interests-basis/. Accessed: 2022-04-03.

[65] Information Commissioner's Office. Update report into adtech and real time bidding. 2019.

[66] Stefan Palan and Christian Schitter. Prolific. ac—a subject pool for online experiments. *Journal of Behavioral and Experimental Finance*, 17:22–27, 2018.

[67] Thomas V Perneger, Delphine S Courvoisier, Patricia M Hudelson, and Angèle Gayet-Ageron. Sample size for pre-tests of questionnaires. *Quality of Life Research*, 24(1):147–151, 2015.

[68] Victor Le Pochat, Tom Van Goethem, Samaneh Tajalizadehkhoob, Maciej Korczyński, and Wouter Joosen. Tranco: A research-oriented top sites ranking hardened against manipulation. *Proceedings of the 26th Annual Network and Distributed System Security Symposium (NDSS)*, 2019.

[69] Cristiana Santos, Midas Nouwens, Michael Toth, Nataliia Bielova, and Vincent Roca. Consent management platforms under the gdpr: processors and/or controllers? In *Annual Privacy Forum*, pages 47–69. Springer, 2021.

[70] Cristiana Santos, Arianna Rossi, Lorena Sanchez Chamorro, Kerstin Bongard-Blanchy, and Ruba Abu-Salma. Cookie banners, what's the purpose? Analyzing cookie banner text through a legal lens. In *Proceedings of the 20th Workshop on Workshop on Privacy in the Electronic Society*, pages 187–194, 2021.

[71] Eunjin Seong and Seungjun Kim. Designing a crowdsourcing system for the elderly: A gamified approach to speech collection. In *Extended Abstracts of the 2020 CHI Conference on Human Factors in Computing Systems*, pages 1–9, 2020.

[72] Caroline Sinders. What's In a Name? Unpacking Dark Patterns versus Deceptive Design. Available at https://medium.com/@carolinesinders/whats-in-a-name-unpacking-dark-patterns-versus-deceptive-design-e96068627ec4 (2022/06/18).

[73] Richard H Thaler and Cass R Sunstein. *Nudge: Improving Decisions About Health, Wealth, and Happiness*. Yale University Press, 2008.

[74] Siny Tsang, Colin F Royse, Abdullah Sulieman Terkawi, et al. Guidelines for developing, translating, and validating a questionnaire in perioperative and pain medicine. *Saudi journal of anaesthesia*, 11(5):80, 2017.

[75] Joseph Turow, Michael Hennessy, and Nora Draper. Persistent misperceptions: Americans' misplaced confidence in privacy policies, 2003–2015. *Journal of Broadcasting & Electronic Media*, 62(3):461–478, Jul 2018.

[76] Christine Utz, Martin Degeling, Sascha Fahl, Florian Schaub, and Thorsten Holz. (Un)informed consent: Studying GDPR consent notices in the field. In *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*, pages 973–990, 2019.

[77] Michael Veale, Midas Nouwens, and Cristiana Santos. Impossible Asks: Can the Transparency and Consent Framework ever authorise real-time bidding after the Belgian DPA decision? *Technology and Regulation*, 2022:12–22, Feb. 2022.

[78] Ari Ezra Waldman. Cognitive biases, dark patterns, and the 'privacy paradox'. *Current Opinion in Psychology*, 31:105–109, 2020.

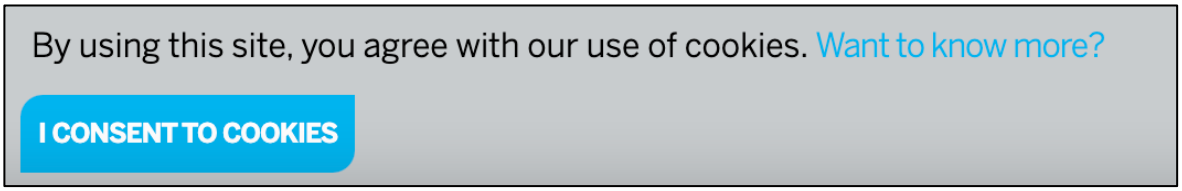
[79] Tal Z Zarsky. Incompatible: The GDPR in the age of big data. *Seton Hall L. Rev.*, 47:995, 2016.

[80] Shoshana Zuboff. *The age of surveillance capitalism: The fight for a human future at the new frontier of power*. Profile Books, 2019.

# “Investigating Deceptive Design in GDPR’s Legitimate Interest”: Supplementary Materials (CHI 2023)

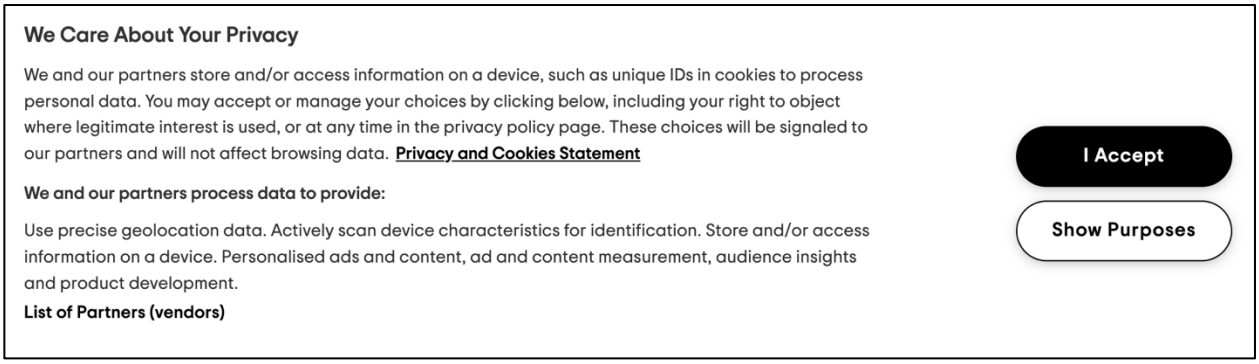
## Section 1: Images

1.




2.

3.



4.

BACK

## We value your privacy

Review and object to processing of personal data without your consent on the basis of a legitimate interest for each purpose and by each partner below. Expand each purpose or partner list item for more information to help make your choice. To object to the special purposes of ensuring security, preventing fraud, and debugging, and technically delivering ads or content click on a partner's privacy policy link.

OBJECT ALL ACCEPT ALL

**LEGITIMATE INTEREST PURPOSE(S)**

- Select basic ads
- Create a personalised ads profile
- Select personalised ads
- Create a personalised content profile
- Select personalised content

PARTNERS LEGITIMATE INTEREST SAVE & EXIT

5.

## We value your privacy

Reject all Accept all

We and our partners store and/or access information on a device. Cookies, device identifiers, or other information can be stored or accessed on your device for the purposes presented to you.

Ads and content can be personalised based on a profile. More data can be added to better personalise ads and content. Ad and content performance can be measured. Insights about the audiences who saw the ads and content can be derived. Your data can be used to improve existing systems and software, and to develop new products

Some partners do not ask for your consent to process your data, and instead rely on their legitimate interest. View our list of partners to see the purposes they believe they have legitimate interest for and how you can object to it.

Your choices on this site will be applied for this site. You can change your settings at any time, including by withdrawing your consent, by clicking the lock icon in the bottom right or left hand

Read more to accept preferences

Purposes Partners

## Section 2: TCF purposes

| Purpose | Explanation (taken from the TCF) |
|---|---|
| Select basic ads | Ads can be shown to you based on the content you're viewing, the app you're using, your approximate location, or your device type. |
| Create a personalized ads profile | A profile can be built about you and your interests to show you personalised ads that are relevant to you. |
| Select personalized ads | Personalised ads can be shown to you based on a profile about you. |
| Create a personalized content profile | A profile can be built about you and your interests to show you personalised content that is relevant to you. |
| Select personalized content | Personalised content can be shown to you based on a profile about you. |
| Measure ad performance | The performance and effectiveness of ads that you see or interact with can be measured. |
| Measure content performance | The performance and effectiveness of content that you see or interact with can be measured. |
| Apply market research to generate audience insights | Market research can be used to learn more about the audiences who visit sites/apps and view ads. |
| Develop and improve products | Your data can be used to improve existing systems and software, and to develop new products. |

## Section 3: Codebook

The 87 codes and 8 themes identified related to legitimate interest in privacy notices. The "Group" is used to further organize codes.

| Theme | Group | Codes |
|---|---|---|
| **Stakeholders**: those involved in the online consent ecosystem, and interested in user data | *Service provider*: the company providing the service | "We" |
| | *Consent authorities*: those with a role in creating consent standards | IAB Europe and TCF<br><br>Consent management platforms (CMPs) |
| | *3rd parties*: companies not directly providing the service, but still collecting user data | Google<br><br>Social media partners<br><br>Ad-tech providers |

| | | |
|---|---|---|
| | | "Trusted partners"<br><br>TCF vendors<br><br>"Pre-selected companies"<br><br>Analytics partners<br><br>IAB vendors |
| **Extent** to which consent and legitimate interest choices apply | *Duration:* how long users' choices apply | Choices apply for 6 months<br><br>Will not be asked to consent again for<br><br>15 days<br><br>No duration present |
| | *Reach:* which website(s) users' choices apply to | Choices only apply to that website<br><br>User info is shared with 3rd parties<br><br>Choices apply to service provider and their group of websites<br><br>Nothing indicated |
| **Purposes**: the purposes for which data is collected and used | *Legitimate interest purposes*: all of these are legitimate interest purposes listed in the TCF | Select ads<br><br>Develop and improve products<br><br>Create personalized ad profile<br><br>Select personalized ads<br><br>Create personalized content profile<br><br>Select personalized content |

| | | |
|---|---|---|
| | | Measure ad performance<br><br>Measure content performance<br><br>Market research for audience insights |
| | *Special purposes*: all these are also special purposes listed in the TCF | Store and access data<br><br>“Special purposes”<br><br>Security, debugging, preventing fraud<br><br>Deliver ads and content |
| | *Benefits to user:* ways privacy notices frame data collection to make it sound appealing to users | Website and business operation<br><br>“Data is used to improve...”<br><br>View website content<br><br>More data means better results<br><br>Keeps service free<br><br>Website functions properly |
| **Deceptive design elements:** elements of legitimate interest in privacy notices that can deceive users | *Linguistic elements:* ways text is used to deceive users | Placebic definition of what legitimate interest is<br><br>Alludes to legitimate interest, without saying it explicitly<br><br>No mention of what "Legitimate Interest" means |
| | *Complex choice architecture*: UI design elements that are overly complicated, and requires more time for users to navigate | Presence of a legitimate/consent toggle<br><br>Object to legitimate interest by vendor and/or purpose |

| | | |
|---|---|---|
| | | Expand each legitimate interest item to learn more and object<br><br>Object to legitimate interest in privacy policy<br><br>No legitimate interest-specific object option |
| | *General design elements:* broader UI design elements that deceive users | No legitimate interest object all button<br><br>Legitimate interest object button present in a deeper layer<br><br>Hard to read (e.g., small font, block of text) |
| **Types of cookies**: cookies or technologies being used to track and collect data | *Cookies* | Functional cookies<br><br>Always active cookies<br><br>Strictly necessary cookies<br><br>Performance cookies<br><br>Statistical cookies<br><br>Recommended cookies<br><br>Targeting cookies |
| | *Other forms of tracking technology* | "Cookie-equivalent technology" |
| **Data that is being collected** | *Website interactions*: the data from a user's interactions with the website,<br><br>possibly 3rd parties, which is collected | Visited pages<br><br>Time of visit<br><br>Frequency of visit<br><br>"Standard information"<br><br>Browsing data |

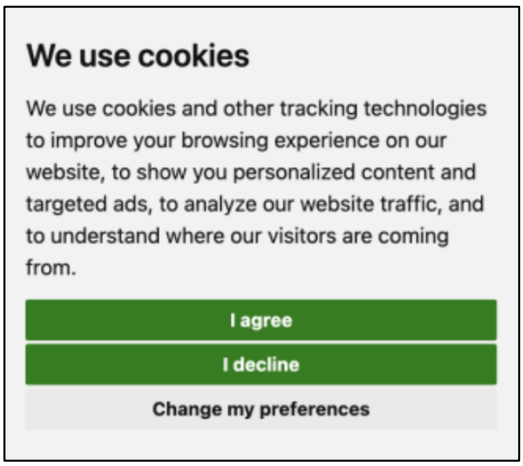
| | | |
|---|---|---|
| | | URLs visited |
| | *Device information:* information obtained from the device is collected | IP address<br><br>Geolocation data<br><br>Cookie IDs<br><br>Device data<br><br>Match and combine data from<br><br>different sources |
| | Identification: sensitivity of the information collected and its abilities to identify the user | “Non-sensitive information”<br><br>"Does not (usually) directly identify you" |
| **Framing**: the way consent notices describe user privacy and legitimate interest | *User rights*: companies frame privacy in a way that indicates users have choices and rights | Users have a right to object<br><br>“Privacy is a priority”<br><br>"We value your privacy" |
| | *Legitimate interest framing:* how legitimate interest is defined or referred to in privacy notices | Legitimate business interest<br><br>Rely on legitimate interest rather than consent<br><br>Processing without your consent<br><br>Objection does not mean collection is prevented<br><br>Your consent, our legitimate interests<br><br>Legitimate interest is subjective (some privacy notices frame it as if it is just what the data controller thinks is a legitimate interest) |

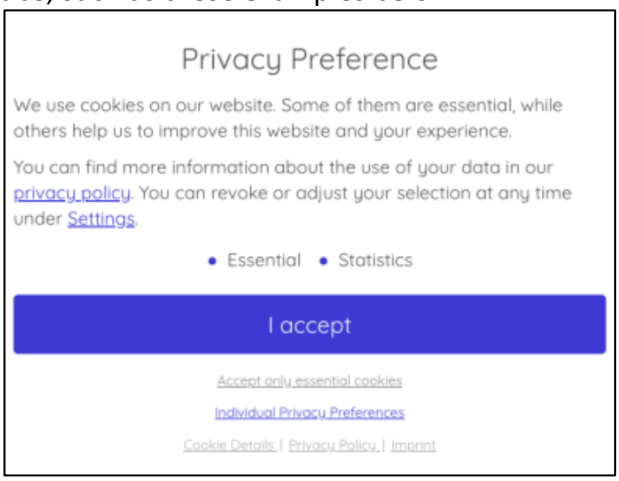
| | | |
|---|---|---|
| | | Take objections into consideration for future site development |
| **Legitimate interest-related actions:** actions users can take when they encounter legitimate interest in a privacy notice | *Manage choices:* privacy notices offer users an option to manage their legitimate interest choices | Users can object to all legitimate interest purposes and vendors<br><br>Users can object to legitimate interest for some purposes and/or vendors<br><br>Object to legitimate interest in privacy policy<br><br>Make a granular choice |
| | *Transparency*: ways users can find out more about how their data is being used | View vendors<br><br>Review data purposes |

## Section 4: Survey

### Background Questions

1. Have you ever come across a consent notice, such as these examples below:




   a. Yes
   b. No
   c. Not sure

2. Have you ever adjusted your privacy preferences using consent notices? For example, clicking “Change my preferences" on the first screenshot.
    a. Yes
    b. No
    c. Not sure
3. How concerned are you about your data privacy when using the Internet?
    a. Not concerned at all
    b. Not very concerned
    c. Somewhat concerned
    d. Very concerned
4. How much control do you feel like you have over whether your data is collected online?
    a. A lot of control
    b. Some control
    c. Not very much control
    d. No control at all

## Vignette Section

*Imagine you are entering a [news/e-commerce/search engine/social media/government/non-profit/entertainment/banking] website, such as the one below. You enter the website, and see a consent banner appear.*

[The same questions appeared for the following three purposes]

**Functional or Strictly Necessary** means to enable you to move around the website and use its features, such as logging in, authentication, shopping basket, e-billing and interacting with your device.

**User experience improvement** means to collect and process information about your use of the website to provide you with personalized enhanced features, like to remember the choices that you made (username, the language, region you are in, fonts, text size, etc).

**Sharing data with third parties** means to share your information with third-parties beyond the website you are visiting.

Questions 5, 7, 9. I think this purpose is essential for the functioning of this type of website and service offering.

a. Complete disagree
b. Somewhat disagree
c. Neither agree nor disagree
d. Somewhat agree
e. Completely agree

Questions 6, 8, 10. Rate how much you think this purpose benefits each group:
[rate from 1- Not at all, 2 – A little, 3- A moderate amount, 4 – A lot]

a. The user (if I were to use this website)
b. The company offering the service
c. Third parties (e.g. advertising companies)
d. Other users of the website/service
e. Society

*Sometimes, websites might collect data for the following purposes without asking for permission. For each of the following data collection purpose, how comfortable are you with this:*

[The same questions appeared for the following eight purposes]

**Personalized content delivery and measurement**: create and display personalized content that is relevant to you, content you interact with are measured for performance and effectiveness.

**Personalized ad delivery and measurement**: deliver, personalize ads, select and measure the effectiveness of these ads. Advertising and marketing material can be shown to you based on the content you're viewing, the app you're using, your approximate location, or your device type. Ads you interact with are measured for performance and effectiveness.

**Analytics, statistics, audience insights:** measure, improve and report on your engagement with the website service, like the number of unique visits to a website, how long users stay in the site, what parts and pages of the website are browsed, main searched keywords, etc. Apply market research to learn more about audiences who visit sites/apps and view ads.

**Developing and improving products:** your data can be used to improve existing systems and software, and to develop new products and functionalities.

**Future innovations:** your data can be used for future innovations unrelated to the service the website currently provides.

**Archiving data for scientific or historical research, public interest, statistical purposes:** Your data can be used for future archiving purposes in the public interest, scientific or historical research purposes or statistical purposes.

**Security and debugging:** your data can be used to ensure systems are working securely.

**Fraud detection and law enforcement:** your data can be used to monitor for and prevent fraudulent activity, and indicating possible criminal acts and threats to public safety.

Questions 11, 13, 15, 17, 19, 21, 23, 25. How comfortable are you with sharing data for this purpose **without your permission?**

a. Not comfortable at all
b. Not comfortable

c. Neither comfortable nor uncomfortable
d. Somewhat comfortable
e. Very comfortable

Questions 12, 14, 16, 18, 20, 22, 24, 26. Rate how much you think this purpose benefits each group:
[rate from 1- Not at all, 2 – A little, 3- A moderate amount, 4 – A lot]

a. The user (if I were to use this website)
b. The company offering the service
c. Third parties (e.g. advertising companies)
d. Other users of the website/service
e. Society

## Legitimate Interest Questions

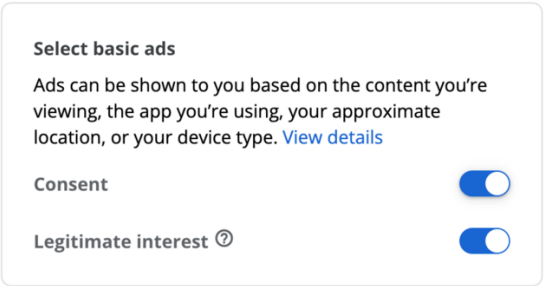
27. When a website tells you they are collecting data for "legitimate interest" purposes, whose legitimate interests do you think they mean? [Select all that apply]

a. Your (the user's) legitimate interest
b. The company's (offering the service) legitimate interest
c. Advertisers' legitimate interest
d. Society's legitimate interest
e. Other website users' legitimate interest
f. Unsure

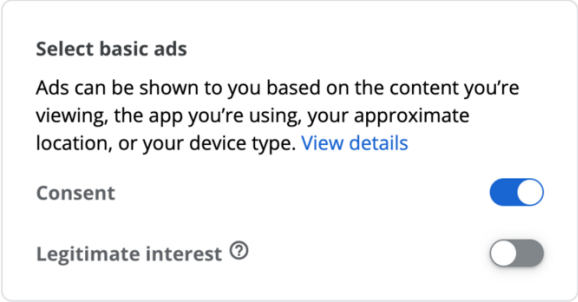
[this section is shown on the next page, after Q27 has been answered]
*"Legitimate Interest" under the GDPR is defined as data processing that is necessary for the legitimate interests of the data controller (e.g., websites offering a service), or third parties (e.g., advertising companies).*

28. Under which scenarios do you think your data would be collected? (select all that apply)

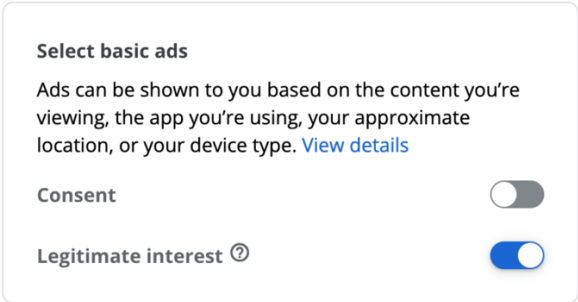
a. When both toggles are active:



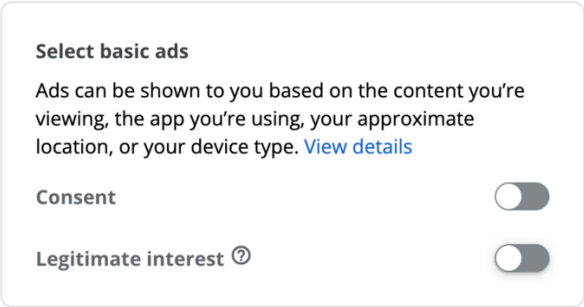
b. When only the "Consent" toggle is active:




c. When only the "Legitimate Interest" toggle is active:




d. When neither toggle is active:




29. What could be some downsides or harms of sharing personal data to companies for legitimate interest purposes?
[open response]

## Demographics

Questions 30 – 39. How familiar are you with the following computer and Internet-related items? Please choose a number between 1 and 5 where 1 represents “no understanding” and 5 represents “full understanding” of the item.

30. Spyware
31. Cache
32. Phishing
33. Privacy settings

34. Meme
35. Tagging
36. Followers
37. Viral
38. PDF

39. What age group are you in?
a. 18 - 24
b. 25 - 34
c. 35 - 44
d. 45 - 54
e. 55+

40. What gender do you identify as?
a. Male
b. Female
c. Non-binary / third gender
d. Prefer not to say

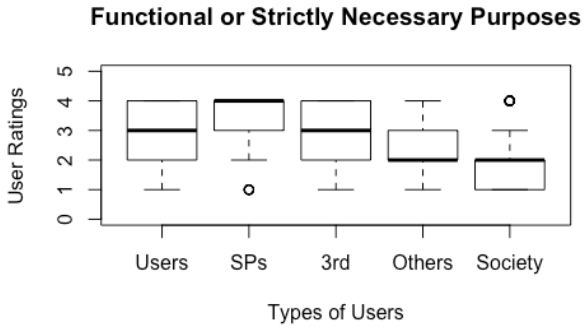
41. How long have you been living in the European Union?
a. I don't currently live in the EU
b. Less than a year
c. Less than 4 years
d. 4+ years

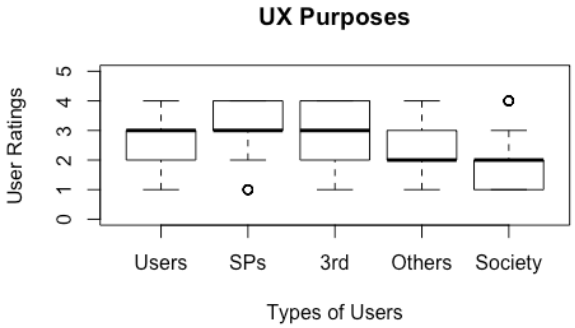
42. Where in the European Union do you live?
[drop-down of all EU countries + an option for “Other”]

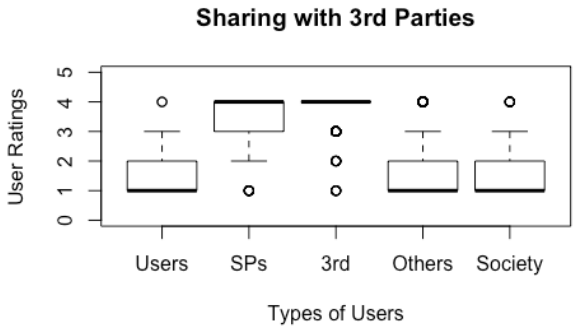
43. What language do you primarily use the internet in?
[drop-down of languages spoken in the EU + an option for “Other”]

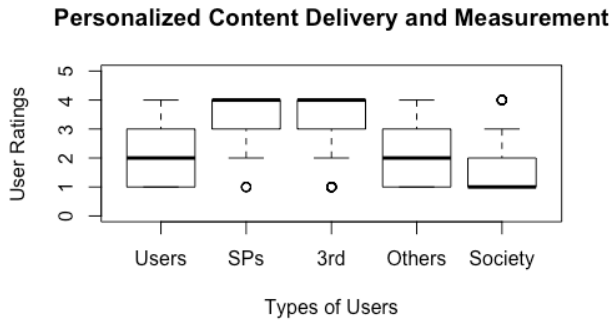
## Section 5: Additional plots

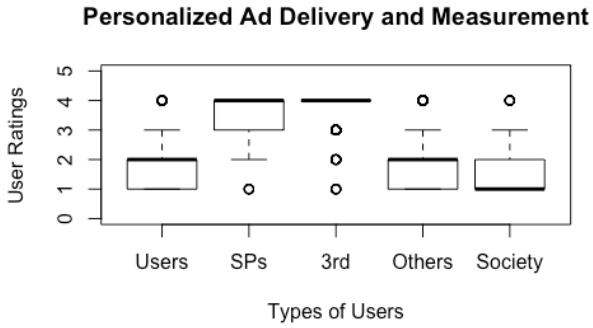
1. Plots for user ratings of how much each user group benefits from the following purposes

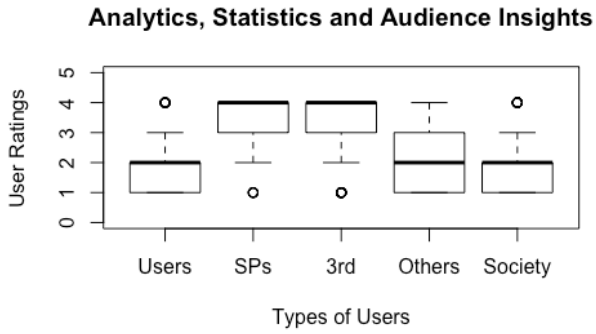


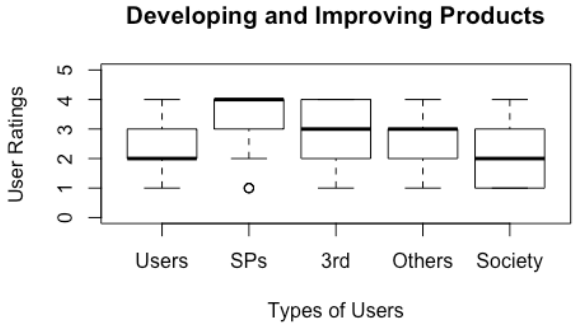



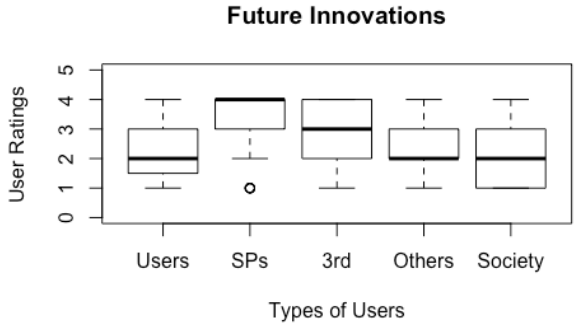

Sharing with 3rd Parties
User Ratings
0 1 2 3 4 5
Users
SPs
3rd
Others
Society
Types of Users

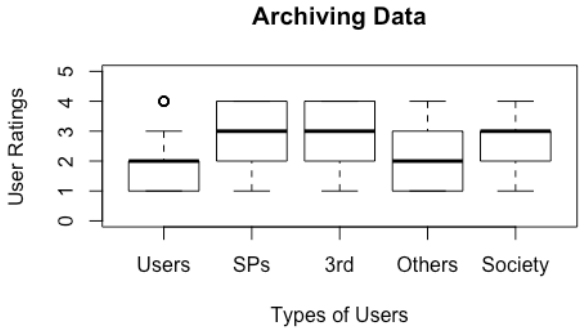

Personalized Content Delivery and Measurement
User Ratings
0 1 2 3 4 5
Users
SPs
3rd
Others
Society
Types of Users

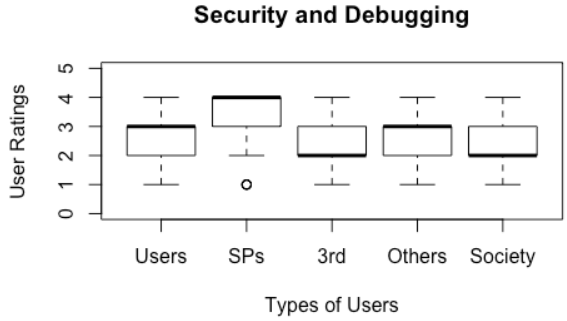

Personalized Ad Delivery and Measurement
User Ratings
0 1 2 3 4 5
Users
SPs
3rd
Others
Society
Types of Users

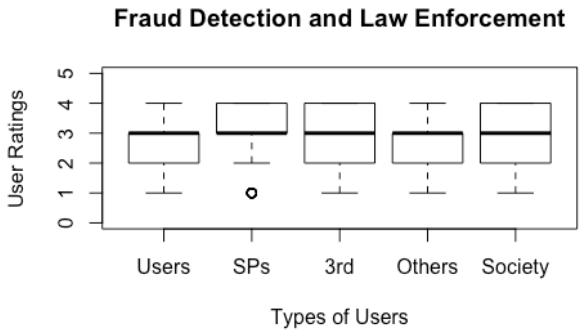

Analytics, Statistics and Audience Insights
User Ratings
0 1 2 3 4 5
Users
SPs
3rd
Others
Society
Types of Users


Developing and Improving Products
User Ratings
0 1 2 3 4 5
Users
SPs
3rd
Others
Society
Types of Users


Future Innovations
User Ratings
0 1 2 3 4 5
Users
SPs
3rd
Others
Society
Types of Users


Archiving Data
User Ratings
0 1 2 3 4 5
Users
SPs
3rd
Others
Society
Types of Users


Security and Debugging
User Ratings
0 1 2 3 4 5
Users
SPs
3rd
Others
Society
Types of Users




2. Correlation matrix of how much each data collection purpose is correlated to each other

| | functional | UX | share | content | ads | analytics | developing | innovations | archive | security | fraud |
|---|---|---|---|---|---|---|---|---|---|---|---|
| functional | | 0.029 | -0.085 | 0.115 | -0.021 | 0.088 | 0.084 | 0.015 | 0.116 | 0.156 | 0.07 |
| UX | 0.029 | | 0.356 | 0.097 | 0.224 | 0.081 | 0.105 | 0.15 | 0.015 | 0.084 | 0.119 |
| share | -0.085 | 0.356 | | 0.217 | 0.328 | 0.108 | 0.036 | 0.174 | -0.004 | -0.041 | -0.011 |
| content | 0.115 | 0.097 | 0.217 | | 0.613 | 0.494 | 0.479 | 0.418 | 0.347 | 0.358 | 0.25 |
| ads | -0.021 | 0.224 | 0.328 | 0.613 | | 0.513 | 0.496 | 0.459 | 0.301 | 0.314 | 0.375 |
| analytics | 0.088 | 0.081 | 0.108 | 0.494 | 0.513 | | 0.631 | 0.537 | 0.45 | 0.47 | 0.388 |
| developing | 0.084 | 0.105 | 0.036 | 0.479 | 0.496 | 0.631 | | 0.638 | 0.477 | 0.576 | 0.438 |
| innovations | 0.015 | 0.15 | 0.174 | 0.418 | 0.459 | 0.537 | 0.638 | | 0.471 | 0.493 | 0.468 |
| archive | 0.116 | 0.015 | -0.004 | 0.347 | 0.301 | 0.45 | 0.477 | 0.471 | | 0.489 | 0.421 |
| security | 0.156 | 0.084 | -0.041 | 0.358 | 0.314 | 0.47 | 0.576 | 0.493 | 0.489 | | 0.559 |
| fraud | 0.07 | 0.119 | -0.011 | 0.25 | 0.375 | 0.388 | 0.438 | 0.468 | 0.421 | 0.559 | |

Data Collection Purpose

## Section 6: Description, reasoning, and sources behind the purposes we included in our survey

| Purpose and definition presented | Source(s) and reasoning |
|---|---|
| **Functional or strictly necessary**: enables you to move around the website and use its features, such as logging in, authentication, shopping basket, e-billing, and interacting with your device | According to previous research has shown that this is a commonly used data collection purpose [66]. We wanted to investigate whether users feel this is actually strictly necessary, and therefore a possible contender as a legitimate interest purpose. |
| **User experience improvement**: collect and process information about your use of the website to provide you with personalized enhanced features, like to remember the choices that you made (username, the language, region you are in, fonts, text size, etc.) | User experience improvements is used by 61% of sites analyzed in a study [66]. |
| **Sharing data with third parties:** sharing your information with third-parties beyond the website you are visiting. | Previous work has looked at user perceptions of sharing data for advertising [12]. For our study, we wanted to see general reactions to sharing user data with third parties. |
| **Personalized content delivery and measurement**: create and display personalized content that is relevant to you, content you interact with are measured for performance and effectiveness. | This amalgamates the TCF's legitimate interest purposes of *Create a personalized content profile, Select personalized content, and Measure content performance* [23]. |
| **Personalized ad delivery and measurement:** deliver, personalize ads, select and measure the effectiveness of these ads. Advertising and marketing material can be shown to you based on the content you're viewing, the app you're using, your approximate location, or your device type. Ads you interact with are measured for performance and effectiveness. | This amalgamates the TCF's legitimate interest purposes of *Create a personalized ad profile, Select personalized ads,* and *Measure ad performance*, [23]and GDPR's recommendation that *Direct Marketing*: the communication (by whatever means) of any advertising or marketing material which is directed to particular individuals (recital 47) be included as a legitimate interest purpose [13]. |
| **Analytics, statistics, audience insights:** measure, improve and report on your engagement with the website service, like the number of unique visits to a website, how long users stay in the site, what | This is the TCF's purpose of *Apply market research to generate audience insights*, but we changed the name to be more succinct and understandable to end-users [23]. |

| | |
|---|---|
| parts and pages of the website are browsed, main searched keywords, etc. Apply market research to learn more about audiences who visit sites/apps and view ads. | |
| **Developing and improving products:** Your data can be used to improve existing systems and software, and to develop new products and functionalities. | This is from the TCF's purpose of *Develop and improve products* [23]. |
| **Future innovations**: your data can be used for future innovations unrelated to the service the website currently provides. | Previous research have discussed the undesirability of data minimization, as it interferes with future innovations [26, 75]. We wanted to investigate how users felt about this purpose. |
| **Archiving data for scientific or historical research, public interest, statistical:** your data can be used for future archiving purposes in the public interest, scientific or historical research purposes or statistical purposes. | Article 89 of the GDPR says that data can be collected without consent for *Processing personal data for archiving, scientific research or historical or statistical purposes*: Your data can be used for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes [13] |
| **Security and debugging**: your data can be used to ensure systems are working properly and securely. | This purpose amalgamates *Ensure security, prevent fraud, and debug* from the TCF's special purposes [23] and the GDPR's recommendation that *Network and information security* be a legitimate interest purpose [13]. |
| **Fraud detection and law enforcement**: your data can be used to monitor for and prevent fraudulent activity, and indicating possible criminal acts and threats to public safety | This purpose amalgamates *Ensure security, prevent fraud, and debug* from the TCF's special purposes [23], the GDPR's recommendation that *Fraud prevention purposes* (recital 47), and *Indicating possible criminal acts or threats to public safety* (recital 50) be legitimate interest purposes [13], and the Center for Information Policy Leadership's recommendation that *Crime prevention and Compliance with foreign law, law enforcement, court, and regulatory bodies' enforcement* be legitimate interest purposes [27] |

## Section 7: Wilcoxon Results Table

| Legitimate Interest Purpose | Security and debugging | Fraud and Law Enforcement | Personalized ads and measurement |
|---|---|---|---|
| Personalized content and measurement | $Z = 120533$, $p < 0.001^{**}$ | $Z = 113442$, $p < 0.001^{**}$ | $Z = 68364$, $p < 0.001^{**}$ |
| Personalized ads and measurement | $Z = 128966$, $p < 0.001^{**}$ | $Z = 121898$, $p < 0.001^{**}$ | - |
| Analytics | $Z = 107426$, $p < 0.001^{**}$ | $Z = 101278$, $p < 0.001^{**}$ | $Z = 56636$, $p < 0.001^{**}$ |
| Develop and improve products | $Z = 92384$, $p < 0.001^{**}$ | $Z = 86908$, $p = 0.03^{*}$ | $Z = 40175$, $p < 0.001^{**}$ |
| Future innovations | $Z = 106384$, $p < 0.001^{**}$ | $Z = 100084$, $p < 0.001^{**}$ | $Z = 53241$, $p < 0.001^{**}$ |
| Archiving data | $Z = 93902$, $p < 0.001^{**}$ | $Z = 88476$, $p = 0.01^{*}$ | $Z = 43718$, $p < 0.001^{**}$ |
| Security and debugging | - | $Z = 75397$, $p = 0.15$ | $Z = 31034$, $p < 0.001^{**}$ |
| Fraud and law enforcement | $Z = 84603$, $p = 0.15$ | - | $Z = 38102$, $p < 0.001^{**}$ |